

- File No.: EXP202212247

- RESOLUTION OF SANCTIONING PROCEDURE

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

SECOND: Transfer of the complaint.....	2
THIRD: Response to the transfer of the complaint.....	3
FOURTH: Conducting preliminary investigative actions.....	5
FIFTH: Diligence AXESOR.....	9
SIXTH: Diligences Commercial Registry and AXESOR.....	9
SEVENTH: Initiation agreement signed by the director of the AEPD.....	10
EIGHTH: Allegations of the respondent dated 01/05/2024.....	10
NINTH: On 23/10/2024, a resolution proposal is issued, of the literal: 14	
TENTH: Allegations to the resolution proposal.....	14
PROVEN FACTS.....	16
FIRST:.....	16
SECOND:.....	16
THIRD:.....	16
FOURTH:.....	16
FIFTH:.....	17
SIXTH:.....	17
SEVENTH:.....	17
EIGHTH:.....	18
NINTH:.....	19
TENTH:.....	19
LEGAL GROUNDS.....	19
I Competence.....	19
II Definition of biometric and personal data.....	19
III Purpose and aim of the processing.....	27
IV Processing of biometric data: legitimization.....	29
V Data protection impact assessment (DPIA).....	31
VI Response to the allegations regarding the infringement of Article 35 of the GDPR.....	37
VII Exercise of the right of access and consequences of its lack of attention.....	44
VIII Qualification and Typification of the infringements.....	48
IX Determination of the sanctions.....	49
X Adoption of measures.....	57
RESOLVES:.....	58

FIRST: Submission of the complaint

A.A.A. (hereinafter, the complainant) on 11/10/2022, filed a complaint with the Spanish Agency for Data Protection. The complaint is directed against CARTONAJES BAÑERES, S.A. with NIF A03009263 (hereinafter, CB). The reasons on which the complaint is based are as follows:

The complainant states that CB “takes a photograph of the employees' faces from a device located at the entrance” and that (...) it indicates that this photo is used solely for the employees' file and that, “the face is not stored.”

It provides a screenshot of a WhatsApp conversation, (...), no date is visible, with the following content:

- “Is the file about the face? Because I would like to clock in without biometric data. Are there cards or something like that?”

- “No, it must be the face.”

- “...biometric data makes me somewhat uncomfortable.”

- “Don't worry, the face is not stored.”

Additionally, the complainant requested access to their personal data on 29/08/2022, (with a copy of their data subject to processing) specifying purposes and categories of data, stating that they have not received a response to date either by postal mail or by email. A copy of the request is provided,

indicating an email: (...), and their address at ***ADDRESS.1, “so that it can be sent to the indicated address” as contact, with acknowledgment of receipt from CB dated 29/08/22. The complainant indicates that in response to information “that I sent to the company, they informed me via an email dated 14/09 that they are aware of my request for information and that the address of CB will contact to comply with my request regarding the P.D.C.P.”

The complainant provides in document 3 a copy of said email from an address (...) and the logo of that entity.

The complainant adds that there is no information regarding the use of the image.

SECOND: Transfer of the complaint.

In accordance with Article 65.4 of Organic Law 3/2018, of 5/12, on Personal Data Protection and the guarantee of digital rights (hereinafter LOPDGDD), it was given

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/60

transfer of said complaint to the complained party, so that it could proceed to analyze it and inform this Agency within one month of the actions taken to comply with the requirements set forth in the data protection regulations.

The transfer, which was carried out in accordance with the rules established in Law 39/2015, of 1/10, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was recorded on 22/11/2022, as evidenced by the acknowledgment of receipt in the file.

THIRD: Response to the transfer of the complaint

On 22/12/2022, a letter from CB was received in which its representative provided a power of attorney dated 7/07/2022, stating that: “the person designated by SAICA PACK SL, residing at Avda. San Juan de la Peña 144, B50035179, Zaragoza, appears as the ‘sole administrator in the name and representation of CB...’ who grants power to the person designated as the representative of CB, stating:

1) The complainant was an employee of the entity as of ***DATE.1. They acknowledge that exercising the right of access, they provide a copy (document 2) in which they also sign the notice of voluntary resignation from the company on (...), indicating that, respecting the notice period, their last working day is 12/09.

2) “does not obtain a photograph of the employees' faces from a device at the company entrance, as the complainant states,” but rather “The biometric data used in the plant is obtained through a device that serves for employees to clock in and out of the facilities. This device does not take a photograph of any worker, but performs a triangulation of eyes-mouth-nose and pixel counting that allows for the identification of the person.”

The entity states that “after performing the aforementioned triangulation, the system sends to an Excel page the confirmation of the employee's clocking in, which contains only the employee's name, the day, and the time, without storing or transferring any biometric data.

“The Excel file with said data is the only information that is retained.”

3) The entity indicates that the employee was informed of the processing of their data. It provides a copy of the document titled “consent and information on the processing of personal data of employees,” edition 11/01/2022, signed by the complainant on 11/05/2022.

It begins by informing that CB is the responsible party for the processing, adding:

- “read the conditions and sign the consent.” “In case you do not provide your express consent, CB will not be able to process your personal data for the purposes set forth therein. According to the GDPR and the LOPDGDD, by accepting the conditions for the processing of personal data set forth in this document, the interested parties give their express consent for CB to process the data provided in the employee's file in accordance with the previously accepted processing conditions.”

It should be noted that at the bottom of the signature it states “I have read and accept the conditions for the processing of my personal data.”

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
4/60

As separate sections, various headings are listed, and those most significant in relation to the employment object are indicated as follows:

- “Purpose:

to manage the employment relationship between the worker and CB, including those necessary for the preparation of the contract, sending and payment of payroll, as well as withholding of IRPF.

Time control based on the capture of the worker's digital fingerprint for monitoring compliance with the workday.”

- “Legitimacy”: Refers to the applicable regulatory provisions in payroll management and to:

“preparation of the contract. The communication of personal data is a necessary requirement to carry out the employee's registration.”

- “OBLIGATION TO COMMUNICATE” states that “The communication of personal data is a necessary requirement to carry out the registration of the employee, and if they do not give their express consent to the processing, the hiring cannot be carried out.”

- “Categories of data”: Among others, it highlights: “images: photograph-facial scan.”

In the section “rights,” it informs, among other means of exercising them, through sending to the offices by postal mail or delivery at the offices.

The entity states that the claimant was informed of the processing of their data, including biometric data, and “gave their express consent for it.”

4) Regarding the legal basis for the processing and the circumstance that lifts the prohibition on processing special categories of data, according to Article 9 of the GDPR and the purpose of the processing, CB indicates that it provides “the files declared to the AEPD in 2011,” which refers to a letter from the AEPD in which it communicated on 22/06/2011 the registration of files. CB points out that this corresponds to the so-called “payroll, personnel, and human resources,” stating in the purpose “human resources, payroll management, occupational risk prevention, other types of purposes” without any mention of biometric data in the type of data.

5) In relation to the adequate guarantees implemented for the protection of rights and freedoms of individuals, CB provides a document of “privacy policy” published on its website that refers to the information given to users who provide data on the website, as well as to questionnaires that are filled out.

Regarding the access request, CB states, according to the copy they attach in document 1, that they sent an email from the entity named SAICA, informing that the processing has been initiated, and that, within fifteen days following the receipt of the request by the claimant, the response to be sent to the worker would be drafted. They attach the document dated 15/09/2022, which indicates in the body of the letter that it is sent by means of this burofax, informing that the data that appears in the entity are the “basic data of the employment relationship.”

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
5/60

“name, surname, address, phone number, ID number, date of birth, affiliation number, for the fulfillment of labor obligations.”

However, they attempted to connect for the delivery of the requested information both by phone and via WhatsApp, without the individual coming to collect it. Therefore, on 9/12/2022, a written response to the access request was sent via burofax.

The entity has provided a copy of the burofax sent on 9/12/2022.

It is noted that the burofax begins with “We are responding to your letter dated August 29, 2022, by means of this burofax, given that you did not collect this communication during the month of

September as you indicated.” The burofax is addressed to a different address than the one the claimant provided in their request, with the reason unknown.

Additionally, the facial recognition data for labor control carried out is not mentioned.

6) Regarding the Impact Assessment of the data processing operations on the protection of personal data, conducted or reasons for not having conducted it, no response was provided.

7) In relation to the measures adopted to prevent similar incidents, dates of implementation, and controls to verify effectiveness, they respond that the procedure is adequate, as “when hiring a worker, informed consent is obtained, indicating the processing of their data,” and upon termination of the relationship, the data is deleted.

8) Regarding the decision made concerning this complaint, CB states that “it prepared and communicated the response regarding the complaint to the worker and their data was deleted, except for those that must be retained by law,” and “regarding their biometric data, it was deleted from the system.”

THIRD: Admission of the complaint for processing.

On 11/01/2023, in accordance with Article 65 of the LOPDGDD, the complaint submitted by the claimant was admitted for processing.

FOURTH: Conducting preliminary investigative actions.

The General Sub-Directorate of Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to the control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions of Title VII, Chapter I, Section two, of the LOPDGDD, being aware of the following points:

On 31/05/2023, an on-site inspection was conducted at the establishment of CARTONAJES BAÑERES, located in Polígono Industrial Barrio Les Molines, 22, 03450, Banyeres de Mariola, Alicante, from which the following is derived:

1. It is stated by those inspected that CARTONAJES BAÑERES, S.A. “was acquired by SAICA PACK S.L. on 7/07/2022,” an entity with its registered office in Zaragoza.

6/60

copy of the notarial deed of sale of nominative shares representing 98.52% of the share capital of CB.

2. The inspected parties state that on 06/05/2022, the minutes of the establishment of the DATA PROTECTION DELEGATES COMMITTEE of the SAICA GROUP (hereinafter CDPD) were held.

Notable meetings of the CDPD include:

- 19/10/2022, in the copy of the document provided (minutes of the CPD of 19/10/2022), in agreement 7, it is stated: “given the recent acquisition by the SAICA group of the entity CARTONAJES BAÑERES, it is agreed to review the situation of the aforementioned company regarding Data Protection. It is also agreed to recommend to the company that it proceed immediately with the replacement of the current timekeeping system as it employs biometric data.”

- 20/01/2023, according to the copy of the document provided (minutes of the CPD of 20/01/2023 document 5), in the second agreement, it is noted: “agenda” “adaptation of employee control to Regulation 2016/679” and that, “the requirements received from the AEPD regarding the complaint filed by a former employee of CB, now a company of the Group, are reviewed,” “since the company was acquired, work has been ongoing to eliminate the current employee identification system and implement a new system that does not require biometric data.” “It is also noted that the development of a new work plan audited by an independent third party for the adaptation of the plant to the requirements of Regulation 2016/679 has been initiated.”

It is also included in the third point, that it is agreed upon regarding access requests, that the Committee defines aspects of the response time, information that must be provided, and the period that the entity must retain, in order to comply with the requirements established by the regulations.

3.

They provide a copy of:

3.1- document from April 23, “plan for the preparation of the RAT and GDPR Audit” for CB, which consists of a service provision offer related to information, security, and data protection, signed by CB on 28/04/2023.

3.2- budget and order for the new timekeeping system dated 14/03/2023, subject “terminal and cards for the new SAICA plant,” requesting 175 cards.

3.3- “Implementation plan for the timekeeping system” “integration plan SAICA CARTONAJES BAÑERES” initial date 20/03. The phases of development are listed: Analysis and design, construction and validation, and production deployment with the various responsible parties executing them and total hours. The same sheet is dated 23 and another on 25/05/2023. On 29/05 it states “project completed.”

3.4- “Internal communication of the change of timekeeping system” dated 25/05/2023, in which it is informed that, as of 29/05/2023, the new timekeeping system using individualized cards will come into operation, following the standard system used in all SAICA Group plants. It is reminded that “the processing of personal data of employees is necessary for compliance with a legal obligation arising from the contract.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/60

of work with the purpose of fulfilling it and the obligations arising from said labor relationship.

I.”

In this regard, the Inspection Service of the Agency verifies that, at the time of the inspection, the clock for time registration requests an employee identification card and once contact is made, it must be keyed in whether it is an entry or exit.

3.5-DOCUMENTATION ON “OLD TIME REGISTRATION SYSTEM,” titled “facial biometric treatment,” signed by the company SABACOINSA SL, undated, containing the following highlights:

3.5.1- The “3D facial recognition terminal” was of the brand ***BRAND.1 and used a patented facial recognition reader called (...), with a false acceptance rate (FAR) of less than 0.001%, and a false rejection rate (FRR) of less than 1%, “algorithm (...)”

3.5.2- In “biometric pattern capture mode,” it is indicated that: “The capture of the biometric pattern is based on taking several images of the face and using a mathematical algorithm to generate a pattern. This encryption algorithm ((...) algorithm) generates a representative template of said pattern (hash) and is stored in the equipment and in the software to enable biometric identification.”

It provides a long list of sequences of numbers, letters, and alternating signs, which would constitute a “hash (biometric pattern).”

3.5.3- “It is impossible to obtain the real image of the face with the pattern stored in the terminal, as no image of the face is stored, but rather a mathematical relationship is established between certain points of it—singularities, characteristic points—resulting in a set of numbers that will later serve to unequivocally identify each person.”

It is not possible to obtain the image of a face with the stored hash.

This procedure consists of verifying a person through a biometric system by comparing their biometric data acquired at the time of verification with a hash stored in the equipment. The search process is one-to-one.

“The procedure is configured according to the criteria established by the European Data Protection Commission which authorizes a verification/authentication consisting of the verification of an individual by a biometric system in comparison between their biometric data—acquired at the time of verification—with a single biometric template stored in a device (i.e., the one-to-one matching search process). Biometric data is not considered of special level in the case of biometric verification/authentication by hash templates that establish one-to-one hash verifications, complying with the criteria of Articles 6 and 9 of the General Data Protection Regulation.” ...” Our management software PHUC Control stores the hash (biometric pattern) provided to us by the facial recognition terminal. This hash is linked to the end user with the user ID in a special table for biometric data.”

“Biometric data is stored in the proprietary database of the PHUC Control time management software, located on the server at the client's facilities.”

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
8/60

In this regard, the Data Inspection has verified that the company SABACOINSA (web address phuc.es) offers facial recognition solutions for employee attendance control among its products.

3. The Agency's Inspection Service raises the issue that in the documentation submitted to the Agency during the proceedings of the transfer, AT/04915/2022, it was stated that "the device for clocking in and out of employees performs a 'triangulation of eyes-mouth-nose and counts the pixels that allow for the identification of the person, and that once the identification is completed, a confirmation of the employee's clocking is sent to an Excel page that contains only the employee's name, the day, and the time, without storing or transferring any biometric data. The file with this data is the only information that is retained. The hashes were stored in the facial recognition system itself.

In this regard, the entity confirms and adds:

a) This was the operation of the previous clocking system as it was uninstalled as a result of the meeting of the Data Protection Committee where the implementation of a new clocking system was required, which took place in May 2023.

b) They correct that the database manager where employee clockings are recorded is Microsoft Access, not Microsoft Excel as indicated in the documentation.

4. The Agency's Inspection Service raises the statement that already appears: "In the event of an employee's departure, the hash from the facial recognition system is deleted and the data from the Access file of the clockings is stored in a historical record," and in this regard, they state that "all employee clockings since May 2019 are preserved in a historical record following the implementation of the new clocking system," and that the "stored hashes have been destroyed." A copy of a waste management certificate SM0529 from the company WEE INTERNATIONAL RECYCLING SL, dated 2/06/2023, is provided, indicating that on 29/05/2023 they received waste from SAICA NATUR, categorized as "consumer electronics," and three photographs are attached of what appears to be the facial recognition reader (can be seen (...) in the photo on the left), and two other elements, one of which is open and disassembled.

6. Regarding the access right requested from the entity by the claimant, the representatives of the entity state that they contacted the claimant via WhatsApp to ask them to come and collect the response and subsequently, "they sent it by fax." In this regard, they provide a printout of WhatsApp messages exchanged with the claimant on 16/09/2022, as they indicate to arrange an appointment for its collection. In the messages, it can be seen that the company is requesting the claimant to come to "sign a letter in the presence of (...)" a document that is not defined, despite the claimant insisting that it be sent to them by mail beforehand and in another message, they state that if it is the response to their request, they do not need it to be signed. It is referenced in document 14.

7. The Agency's Inspection Service requests access to the claimant's clocking data, and it is verified that no information is listed.

8. The Agency's Inspection Service, accompanied by the inspected personnel, accesses the premises where the management system of the old application with facial recognition is located, verifying:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
9/60

- The premises are locked and equipped with a video surveillance system and fire detector.

- The computer where the application is installed is connected to the local network and uses the Windows 10 operating system. The database manager is Microsoft Access.

- Identification at the computer is done through a username and password defined in Windows, and access to the application also requires a username and password, but different from the previous ones. Only the human resources manager (currently the production manager) and the IT system

administrator have access credentials to the application.

Access to the application is verified by:

- Users can view the clock-ins made by a user, and the data corresponds to the date and time of entry and exit. Holidays and absences are also listed without specifying the reason.
- The application has tables that allow for the consultation of employee clock-in records with the following data: name and surname, card number, shifts, calendar, and a status indicator for leave.
- The clock-ins for the days 29 and 30/05/2023 are marked as "Absent." The representatives of the entity state that this is because the clock associated with this system was deactivated on 29/05/2023. All of this is documented in document 13.

9. The representatives of the entity provide a copy of the following documentation:

- Document 15, "Data Protection Policy of the SAICA Group - v.2 11/04/2022." It states in the section on "data controller" that "In this document, any reference to the controller will refer to each of the companies that make up the SAICA GROUP," and in the introduction, it is noted that the document aims to "inform the SAICA GROUP of the internal policy it carries out in compliance with the GDPR."
- Document 16: Privacy management standard.

A document is attached with a screenshot of the checks performed.

FIFTH: AXESOR Diligence

On 06/06/2023, a diligence was carried out by the Inspection Service with the information obtained from MONITORIZA.AXESOR.ES, as follows:

- From CARTONAJES BAÑERES, in active status, registered office in Alicante, share capital (...)€, same number of shares, type of company "group parent," 99 employees, sales (...)€.

SIXTH: Diligences from the Commercial Registry and AXESOR

On 30/08/2023, the following was obtained and associated with the file:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/60

a) Registration entries from the Commercial Registry of CARTONAJES BAÑERES, S.A., NIF A03009263, listed as active, and since 01/08/2022, the registration as SOLE ADMINISTRATOR, SAICA PACK SL, published on 09/08/2022.

b) In axesor.es, report of CARTONAJES BAÑERES, S.A. with the following data:

- Date of incorporation 24/06/1957, type of company: group parent, status: active, share capital: (...)€, medium-sized SME,
- Last submitted financial year 2021.
- Activity: manufacturing of corrugated paper and cardboard, manufacturing of paper and cardboard packaging and containers.
- Sales: (...)€.
- (...)
- Turnover 2021: (...)€.
- Nominal value (...)€.
- Listed as sole administrator SAICA PACK SL, date of appointment 01/08/2023.
- Subsidiary and associated companies ELECTRO MARIOLA SL, two employees.

a) In axesor.es, report of SAICA PACK SOCIEDAD LIMITADA NIF: B50035179.

- Type of Company: Group subsidiary.
- Activity: 1721 - Manufacturing of corrugated paper and cardboard; manufacturing of paper and cardboard packaging and containers.
- Size: Large.
- Parent company: SOCIEDAD ANONIMA INDUSTRIAS CELULOSA ARAGONESA, which is listed as a shareholder with a 99.99% stake.

SEVENTH: Initiation agreement signed by the director of the AEPD.

On 15/12/2023, the director of the AEPD agreed:

"TO INITIATE SANCTIONING PROCEDURE against CARTONAJES BAÑERES, S.A., with NIF A03009263, for the alleged infringement of the GDPR in the following articles:

- 35, in accordance with article 83.4.a) of the GDPR and for the purposes of the statute of limitations of the infringement, classified as serious under article 73.t) of the LOPDGDD.

- 12, in accordance with article 83.5.b) of the GDPR, and for the purposes of the statute of limitations of the infringement, classified as very serious under article 72.1.k) of the LOPDGDD."

"for the purposes provided in article 64.2 b) of the LPCAPAP, the corresponding sanction would be an administrative fine of 200,000 euros, for the infringement of article 35 of the GDPR."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/60

GDPR, and an administrative fine of 20,000 euros for the violation of Article 12 of the GDPR, totaling 220,000 euros, without prejudice to what results from the investigation."

EIGHTH: Allegations of the defendant dated 01/05/2024.

1) The defendant states that the timekeeping system referred to in the complaint was established in 2016, and attaches an invoice dated 14/12/2016 - "1 Facial identification terminal, and 1 Presence control software - PHUC Official Distributor." At that time, the LOPDGDD and the GDPR were not applicable, distinguishing between the entry into force, twenty days after its publication in the DOUE, and its application, starting from 25/05/2018. "At the time the timekeeping system was implemented, that regulation was not applicable."

"In the previous applicable regulation, the LOPD 15/1999, biometric data were not classified as specially protected, nor was it required to carry out an EIA."

Furthermore, it adds that, once the GDPR came into force, the performance of such an impact assessment is not required, and inserts a link from the AEPD:

(<https://www.aepd.es/preguntas-frecuentes/2-rgpd/10-evaluacion-deimpacto/FAQ-0227-los-tratamientos-iniciados-antes-de-la-aplicacion-del-rgpd-deben-someterse-a-una-evaluacion-deimpacto#:~:text=No%2C%20el%20mandato%20del%20RGPD,comience%20a%20ser%20de%20aplicaci%C3%B3n>)

"The principle of non-retroactivity of sanctioning provisions is violated, Article 9.3 of the CE, by sanctioning conduct with a regulation that was not in force at the time the facts occurred, also considering Article 40 of Law 40/2015 of 1/10, on the legal regime of the public sector, LRJSP regarding the application of the sanctioning provisions in force at the time the facts occurred." The defendant cites as an example a ruling from the National Court dated 14/05/2021, of which no further details are provided other than the transcription of some paragraphs, coinciding in this regard with the Administrative Litigation Chamber, Section 1, Judgment of 14/05/2021, Rec. 115/2020:

"Therefore, a regulation that was not applicable when the sanctioned facts occurred has been applied retroactively. We must add that the aforementioned regulation could have been applied if it had been more favorable - Article 26.2 of Law 40/2015, of October 1 - but as stated in the Judgment of the Supreme Court of October 30, 2009 - appeal no. 334/2006, F.J.6º - and, in the same sense, in the Judgments of said Court of November 12 and 26, 2020, resulting respectively from appeals numbers 4.039/2019 and 5.285/2019: "[...] the retroactive application of the more beneficial regulation must be made by determining which provision is more favorable, through the contrast between both, previous and subsequent, considered globally.... And such contrast does not exist in the contested resolutions, in which there is not even any mention of Organic Law 15/1999, of December 13, and in which the GDPR and Organic Law 3/2018, of December 5, are applied as if it were the regulation that was in force when the sanctioned facts occurred, in April 2018."

The defendant understands that this judgment is applicable, because in 2016 neither the GDPR nor the LOPDGDD were applicable.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

In the alternative, the respondent states that, given that the "installation of the timekeeping system took place in 2016, the infringement would have prescribed after two years, considering what is stated in Article 73 of the LOPDGDD."

2) It considers the lack of proportionality of the sanction for not having applied any mitigating factor. It argues that the assertion that "there came a time when the respondent determined that it was not appropriate and maintained it for several more months," functioning as an aggravating factor, did not take into account that "prior to the initiation of any type of procedure against it, the timekeeping system was replaced with one that does not involve the processing of biometric data. Once the existence of a problem regarding the timekeeping system was confirmed, the necessary steps were taken to replace the system, and the Administration cannot expect that the change was made immediately." It adds that on 14/03/2023, a new timekeeping system was acquired, a "project plan for its replacement" was established (pages 335 to 336 of the file), and by 31/05/2023, when the inspection took place, the system had already been replaced.

"The replacement of the timekeeping system can in no case be considered an aggravating factor," estimating instead that the mitigating factor of Article 83.2.f) of the GDPR should have been applied.

- Furthermore, the respondent states that CARTONAJES BAÑERES SA was acquired by SAICA PACK on 07/07/2022 (98.52% of the shares), that is, once the access system was installed, making it evident that the respondent had taken actions to avoid the use of the installed system, which is why the mitigating factor of Article 83.2.b) of the GDPR was not applied either.

- It adds that no mitigating factors listed in Article 76 of the LOPDGDD were applied, of which it cites:

- b, for there being no type of relationship between the offender and the processing of personal data.

- c, because no benefit was obtained.

- e, since although no absorption process was carried out, 98.52% of the shares of CARTONAJES BAÑERES were acquired.

- f, it did not affect the rights of minors.

"By not applying a single mitigating factor, it violates the principle of proportionality."

- Regarding the aggravating factors applied, it indicates that compared to other sanctioning files with the same type of infringement, significantly lower sanctions have been imposed and provides a table of such procedures, comparing by employees, amount imposed, and mitigating/aggravating factors.

202100603, 20,000 attendees, 200 thousand euros - Aggravating: type of event with massive attendance.

202209921, 500 workers, 20 thousand euros - Mitigating 76.2.b) (when the PS was initiated, the timekeeping system that processed biometric data was still maintained).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

PS/00120/202135, (...), 90 thousand workers, countless clients including minors, 50 THOUSAND euros, "eight aggravating factors, ONE mitigating factor: 'No recidivism is recorded.'"

- It also considers that a fact is used and subsumed under the type, and at the same time, that fact is used as an aggravating circumstance, as it is estimated that there is negligence and lack of diligence for "having implemented the system and not foreseeing its impact," which is precisely what is typified as an infringement, since what is sanctioned is having carried out biometric data processing without having conducted the corresponding impact assessment.

3 - Regarding the infringement of Article 12 of the GDPR, classified as very serious in Article 72.1.k) of the GDPR, it indicates that the same legal text could be classified as serious, according to Article 73.c) of the LOPDGDD "The obstruction or hindrance or the repeated failure to attend to the rights of access, 'rectification, deletion, limitation of processing or portability of data in processing where identification of the affected party is not required, when the affected party, for the exercise of those

rights, has provided additional information that allows for their identification.”

Or, as minor, in Article 74.c) of the LOPDGDD:

“Not attending to requests for the exercise of the rights established in Articles 15 to 22 of Regulation (EU) 2016/679, unless the provisions of Article 72.1.k) of this organic law apply.”

“Overlooking a series of circumstances that would not justify the classification of the infringement as very serious”:

- On 16/09/2022, “the claimant was informed” that the requested documentation was available, and the claimant indicated that “there was no problem in coming to collect said documentation.”
- On 19/09/2022, a new message was sent for them to come and collect it, indicating this time that the claimant “had other priorities at that moment,” and that is why they could not attend.
- Finally, “a burofax was sent on 9/12/2022.”

The respondent states that, “if the request is examined, it can be seen that it only indicates the street and number and locality, without indicating floor or door, given that they lived in a residential building, so their address was incomplete,” and the “only thing they could do was send the burofax to the only valid address they had.”

The worker was requested numerous times to come to the registered office, which they agreed to, but never attended. Nevertheless, a burofax was sent to the address they had, since the address provided was incomplete.

They understand that the conduct typified as very serious does not occur:

- They consider that the principle of proportionality is violated, showing as an example PS/369/2022 in which the same fine is imposed, with the following differences:
- The case for comparison had four aggravating factors, this one has two; that one treated the data of the affected party without having been a client, there a mitigating factor is valued, in this case none.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

14/60

- Also in this infraction, the Administration employs the same fact to classify the infraction and to apply the aggravating circumstance, as it is estimated that there is negligence and lack of diligence due to the notifications made via WhatsApp and the burofax sent to a different address than the one indicated; however, these circumstances are also taken into account to classify the infraction as very serious and not as serious or minor.

4- It concludes by indicating that, as a result of the above, the initiation agreement has been issued completely disregarding the legally established procedure, therefore it should be declared null according to Article 47.1.e) of the LPACAP or, subsidiarily, annulable according to Article 48 of the same Law.

NINTH: On 23/10/2024, a resolution proposal is issued, with the following text:

“FIRST: That the Director of the Spanish Agency for Data Protection sanctions CARTONAJES BAÑERES, S.A., with NIF A03009263, for the infraction of the GDPR in its articles:

- 35, in accordance with Article 83.4 a) of the GDPR, and for the purposes of the statute of limitations of the infraction, classified as serious in Article 73.t) of the LOPDGDD, with 200,000 euros.
- 15, in accordance with Article 83.5 b) of the GDPR, and for the purposes of the statute of limitations of the infraction, classified as very serious in Article 72.1.k) of the LOPDGDD, with 20,000 euros.

SECOND: That the Director of the Spanish Agency for Data Protection orders CARTONAJES BAÑERES, S.A., with NIF A03009263, under Article 58.2.c) of the GDPR, to prove within 30 days from the date the resolution that concludes this procedure becomes enforceable, that it has complied with the exercise of the claimant's right of access.”

TENTH: Allegations to the resolution proposal

On 12/11/2024, allegations to the resolution proposal are received, which, in summary, indicate:

1- Regarding the INFRACTION OF ARTICLE 35 OF THE GDPR, it reiterates what was stated in the previous allegations of 5/01/2024. It adds:

- It considers that the AEPD errs in the classification, as it is one thing to continue using a facial

recognition tool, and another not to have carried out a DPIA prior to installing the tool. It reiterates on this last point what has already been stated in allegations to the agreement of 5/01/2024.

- "The AEPD states that it is necessary to carry out a DPIA if there have been changes in the risks that the processing implies in relation to the moment when the processing was initiated," "the fact that biometric data is part of the special category does not imply that there is a change in risk," but in this case:

- Neither have new technologies been employed nor are the data used for different purposes, nor are more data or different data collected than those that were used.

- "At no time has it been proven by the acting Administration that there has been..."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

15/60

the change in risks has occurred, therefore it is evident that it is not appropriate to carry out an EIPD."

Additionally, it states that in the proposal:

- it emphasizes that "the infringement attributed to the appearing commercial entity, consisting of not adapting its behavior to carry out an EIPD," is not classified as an infringement. The alleged infringement has been reformulated, indicating: "Therefore, it is also indisputable that treatment has been taking place through the use of the facial biometric system established by the data controller, CB, following the entry into force of the GDPR, to which the defendant has not adapted its behavior to carry out an EIPD, as determined by Recital 171 of the GDPR and as derived from the principles and guarantees applicable in the aforementioned GDPR."

The defendant indicates that the infringement is "not carrying out an impact assessment at the moment when the processing begins," and believes that "the alleged infringement is being incorrectly classified," "since that provision does not sanction the failure to adapt its behavior in accordance with the aforementioned article."

It adds to its reiteration of the PRESCRIPTION of the infringement that, if the obligation to have carried out the assessment arises from the entry into force of the GDPR, 25/05/2018, "dies a quo," "having to adapt that processing to the new regulation," from the date when the obligation should have been fulfilled, the responsibility would be prescribed, as more than two years have passed since the date when the initiation agreement begins, or in other words, the moment of prescription "dies ad quem" would be 25/05/2020.

- Regarding PROPORTIONALITY, it reiterates what was stated in its previous allegations of 5/01/2024, emphasizing that the replacement of the timekeeping system before the start of "any procedure" must be assessed, and that prior to the Inspection of 31/05/2023, the system had been acquired and once CB was acquired on 7/07/2022, "SAICA confirmed the existence of a problem regarding the timekeeping system," and established the Work Plan to implement the system change, CANNOT BE AN AGGRAVATING FACT. The mitigating factor that it indicates should be applied is Article 83.2.f) of the GDPR, which considers that the measure does not need to be taken immediately, but rather that what is relevant is to remedy the infringement and mitigate the adverse effects. It reiterates that the mitigating factor of Article 83.2.b) of the GDPR does not apply either, based on the fact that when the system was installed, the applicable regulation did not require the carrying out of an EIPD, and CB was acquired on 7/07/2022, once the system was installed.

- It adds new resolutions that sanction differently from its case:

- The file 202213792, with three aggravating factors, no mitigating factors, and 700 subscribers, with 50 THOUSAND euros.

- The file 202202960, with two aggravating factors and no mitigating factors, and 4125 employees, with 100 THOUSAND euros.

It considers that the non-application of any mitigating factor violates the principle of proportionality.

- In response to the statement in the proposal that it did not comply with the principle of proactivity by not documenting the reasons for not carrying out an EIPD, with some expert document.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
16/60

specialized who would have drawn such a conclusion, the respondent states that it has already presented its considerations regarding the entry into force of the GDPR and the implementation of the system in 2016, and it is the ADMINISTRATION THAT BEARS THE BURDEN OF PROOF, as the presumption of innocence is guaranteed by the Spanish Constitution. It concludes that it did not carry out the DPIA because "in 2016 this obligation was not contemplated in the regulations."

2 - Regarding the infringement of Article 15 of the GDPR, it reiterates the allegations made on 5/01/2024, although it continues to refer to them as Article 12, requesting the filing of the sanctioning procedure.

PROVEN FACTS

FIRST:

The claimant was an employee of Cartonajes Bañeres (CB) since ***DATE.1, the date on which he communicated his voluntary resignation, effective 12/09/2022 (last working day).

SECOND:

It is recorded that the respondent received on 29/08/2022 the request to exercise the right of access made by the claimant. In it, the contact details for the response to be sent there are listed as the email: (...), and his address at ***ADDRESS.1. The claimant received an initial communication from the respondent via email on 14/09/2022, indicating that the procedure had been initiated, but did not receive a response to the exercise of his right. In the request, he asked for a copy of the data subject to processing.

THIRD:

Regarding the response to the exercise of the claimant's right of access made on 29/08/2022, the respondent has not proven that it has been made effective, and the claimant stated that he has not received a response either by email or at the postal address he provided in his request. The respondent provides as a response a document dated 15/09/2022 sent on 9/12/2022 by burofax to an address that was not the one the claimant indicated in his request, specifically to ***ADDRESS.2, stating that it did so because it understood that since ***ADDRESS.1 was the only one indicated, the floor number and door were missing. Despite being evidenced that personnel from the respondent contacted the claimant via WhatsApp on 16 and 19/09/2022, according to a screenshot provided in previous proceedings by the respondent, it was, according to the text, for him to come and sign a letter in the presence of (...), without any indication or implication that it referred to the response to the exercise of the right.

It is not proven that the aforementioned contacts by the respondent with the claimant had the purpose or aim of delivering the response to the right of access to the claimant; rather, it is evidenced that contact was made through that means, but for other matters that do not prove to refer to the exercise of the right.

It is not recorded that the respondent warned the claimant of the need to rectify his request in any way. Furthermore, in the document that the respondent claims to have sent to give effect to the right, there is a generic reference to the type of data, not to the actual data, with no mention of facial recognition or inferred data from it, daily records.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
17/60

resulting from the daily work hour control, nor to the right to file a complaint with the control authority.

FOURTH:

The respondent submitted on 12/22/2022 in its response to the transfer, a copy of the document:

“consent and information regarding: processing of personal data of employees” signed by the claimant on 05/11/2022. It was indicated that the data provided would be processed to manage the employment relationship, and “time control based on capturing the worker's fingerprint for monitoring compliance with the workday,”

It concludes: “I have read and accept the conditions for the processing of my personal data,” reiterating in its header that “by accepting the conditions for the processing of personal data contained in this document, the interested parties give their express consent,” and that “if they do not provide their express consent, CB will not be able to process their personal data for the purposes outlined therein.” In “legitimization,” it specifies, for example, that payroll management responds to compliance with a legal obligation, without any reference to the legitimization of the employee system for monitoring compliance with the workday. The document does not include any section to select affirmative consent, or to deny it, nor any option to revoke consent, nor ultimately any invitation to accept a processing operation.

FIFTH:

Furthermore, the claimant states that, as an employee, the respondent requires him to clock in at the workplace entrance using a facial recognition device, with no alternative to using any other means.

SIXTH:

In the response to the transfer, on 12/22/2022, CB responded by providing a notarized power of attorney dated 07/07/2022, from SAICA PACK SL as the sole administrator of the former, in its name and representation.

In the Commercial Registry, as of 08/30/2023, the company CB is listed as active, and since 08/01/2022, SAICA PACK SL is registered as the sole administrator.

During the inspection visit conducted by the AEPD Inspection Service on 05/31/2023, CB presented information that CARTONAJES BAÑERES, S.A. “was acquired by SAICA PACK S.L. on 07/07/2022,” presenting the deed of sale of nominative shares representing 98.52% of the share capital of CB, without any indication of the extinction of the legal personality of CB.

CB becomes part of the SAICA GROUP, as stated among others, in the minutes document dated 10/19/2022 from the Data Protection Committee of the SAICA GROUP, established on 05/06/2022.

In the cited minutes, the situation of the entity CB regarding data protection is discussed, among other topics. In subsequent meetings of the CPD, such as that of 01/20/2023, the situation of CB is analyzed.

SEVENTH:

In the AEPD inspection conducted on 05/31/2023, the respondent also submitted the document referenced in FOURTH, 3.5 “DOCUMENTATION ON

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

18/60

OLD TIME CLOCK SYSTEM, titled “facial biometric treatment,” signed by the company SABACOINSA SL, undated, from which it is inferred that:

- The system would use a 3D facial recognition terminal, brand ***BRAND.1, reader referred to as (...). “The capture of the biometric pattern by the camera is based on taking several images of the face, and through a mathematical algorithm, a pattern is generated. This encryption algorithm generates a representative template of said pattern (hash) and is stored in EQUIPMENT and in the SOFTWARE to enable biometric identification.”
- The biometric data is stored in the proprietary database of the PHUC CONTROL time management software, located on the client's facility server.
- The PHUC CONTROL management software stores the hash (biometric pattern) provided by the facial recognition terminal. - This hash is linked to the end user with the user ID in a special table for biometric data.

Additionally, the defendant acknowledges:

- It has a database where the time records of workers are registered, managed by Microsoft Access.

- If a worker leaves, the hash from the facial recognition system is deleted, and the data from the ACCES file of the time records is stored in a historical archive. In the event that an employee leaves the company, the biometric pattern is deleted. The defendant, upon ceasing to use the biometric RF system for time control, destroyed the biometric patterns.
- It is certified that, once identification is completed, information is sent to an ACCESS database with confirmation of the employee's time record, containing the worker's name, date, and time, which is the time registration information that is retained.
- At the time of the inspection visit, 31/05/2023, the time record data of employees since 2019 is retained in a historical Access file due to the implementation of the new daily labor control card system, and the stored hashes that served that system have been destroyed. To this effect, the defendant provides a certificate of waste disposal dated 2/06/2023.

The defendant certifies in allegations that the biometric system used for the daily labor time recognition was acquired on 14/12/2016, providing a copy of a purchase invoice from "Distributor PHUC," without detailing the day of its implementation.

EIGHTH:

Before receiving the transfer of the complaint that the AEPD made to the defendant, the DATA PROTECTION DELEGATES COMMITTEE of the SAICA GROUP (CDPD), established on 6/05/2022, recommended in an agreement dated 19/10/2022 to CB that the facial recognition time clock system be immediately replaced due to the use of biometric data.

It is certified that the defendant continued to use the aforementioned facial biometric treatment system until its effective replacement, carried out on 29/05/2023, with records of employee working hours using that system in the ACCESS database.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

19/60

control schedule as was evidenced in prior investigative proceedings by the Inspection Service conducted on 31/05/2023, accessing the management control application for timekeeping, PHUC control registered version.

The same CDPD agreed on 20/01/2023, that the CB plant was being adapted to the requirements of the GDPR, expressly referring to the attention to the exercise of rights. Specifically, in April 2023, an GDPR audit was projected and the preparation of the RAT with a service provision offer.

On 20/03/2023, a plan for the implementation of the integration of CB into SAICA's timekeeping system was initiated, concluding with the distribution of cards to employees and updating ID cards. CB employees were informed about the operation of the new labor control timekeeping system in a document dated 25/05/2023, notifying them of the effective implementation from 29/05/2023 of the new timekeeping system through individualized cards, similar to that of all other plants of the SAICA GROUP. The inspection service of the AEPD confirmed that the timekeeping system required an identification card.

NINTH:

Based on the legal basis for processing and the circumstance that lifts the prohibition on processing special categories of data, according to Article 9 of the GDPR, the respondent did not respond in the transfer of the complaint, excusing that they had provided "the files declared to the AEPD in 2011," "payroll, personnel, and human resources" and that the complainant had given their express consent for the processing of their data, including for the biometric "fingerprint" for "monitoring compliance with working hours."

TENTH:

CARTONAJES BAÑERES; (CB) according to AXESOR.ES, has as its corporate purpose the manufacture of paper and corrugated cardboard, the manufacture of paper and cardboard packaging and containers, was acquired on 07/07/2022 by SAICA PACK SL, with its publication in the Commercial Registry as the sole administrator of CB registered on 01/08/2022. In axesor.es, CB is listed with its incorporation on 24/06/1957, type of company: group parent, status: active, share capital:

(...)€, SME medium size, last submitted financial year 2021, -sales: (...)€, (...), -turnover 2021: (...)€.

LEGAL GROUNDS

I Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of the LOPDGDD, the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states that: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, this organic law, and the regulatory provisions issued in

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

20/60

its development and, insofar as they do not contradict it, subsidiarily, by the general rules on administrative procedures."

II Definition of biometric and personal data

Biometric data is defined by Article 4.14 of the GDPR:

"'biometric data': personal data obtained from a specific technical processing, relating to the physical, physiological or behavioral characteristics of a natural person that allow or confirm the unique identification of that person, such as facial images or fingerprint data;"

It is worth noting the rest of the definitions contained in Article 4 of the GDPR:

"1) 'personal data': any information relating to an identified or identifiable natural person ('data subject'); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier, such as a name, an identification number, location data, an online identifier, or one or more specific elements of the physical, physiological, genetic, mental, economic, cultural or social identity of that natural person;

2) 'processing': any operation or set of operations performed on personal data or sets of personal data, whether by automated means or not, such as collection, recording, organization, structuring, storage, adaptation or alteration, retrieval, consultation, use, communication by transmission, dissemination or otherwise making available, alignment, restriction, erasure or destruction;"

(...)

"7) 'data controller' or 'controller': the natural or legal person, public authority, agency or other body which, alone or jointly with others, determines the purposes and means of the processing; where the law of the Union or of the Member States determines the purposes and means of processing, the controller or the specific criteria for its designation may be provided by the law of the Union or of the Member States;"

The scope of application of the GDPR extends its protection, as established in its Article 1.2, to the fundamental rights and freedoms of natural persons and, in particular, their right to the protection of personal data, defined in its Article 4.1 of the GDPR as "any information relating to an identified or identifiable natural person ('data subject'); an identifiable natural person is one whose identity can be determined, directly or indirectly, in particular by reference to an identifier, such as a name, an identification number, location data, an online identifier, or one or more specific elements of the physical, physiological, genetic, mental, economic, cultural or social identity of that person."

As already noted in Opinion 4/2007 of the Article 29 Working Party (Art. 29 of Directive 95/46/EC, as a consultative and independent body of the EU), regarding

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

21/60

The concept of personal data (WP136), dated 20/06/2007, defines biometric data as:

“biological properties, physiological characteristics, personality traits or tics, which are, at the same time, attributable to a single person and measurable, even if the models used in practice to technically measure them involve a certain degree of probability. Typical examples of biometric data include those provided by fingerprints, retinal patterns, facial structure, voices, but also hand geometry, venous structures, and even certain deeply ingrained skills or other behavioral characteristics (such as handwriting, pulse, a particular way of walking or speaking, etc.). A particularity of biometric data is that they can be considered both as content of information about a specific person (So-and-so has these fingerprints) and as an element to link information to a specific person (this object has been touched by someone who has these fingerprints, and these fingerprints correspond to So-and-so; therefore, So-and-so has touched this object). As such, they can serve as “identifiers.” Indeed, as they correspond to a unique person, biometric data can be used to identify that person. This dual nature is also present in the case of DNA data, which provides information about the human body and allows for the unequivocal identification of one, and only one, person.”

It can be asserted that, from the biological identity unique to each person, automated technical instruments are used that will allow for the permanent and unambiguous identification of all individuals, as everyone possesses such biological identity (fingerprints, face, voice, iris, etc.).

Biometric data irrevocably changes the relationship between the body and identity, as it makes the characteristics of the human body readable by machines and subject to repeated subsequent use. Biometric data has the particularity of being produced by the body itself and characterizes it definitively; they are data not about that person, but the data refers to the same person, in principle not modifiable by the will of the individual. Furthermore, because biometric data is unique to a person and perpetual, the user utilizes the same data across different systems.

Biometric data can be processed and stored in various ways. Sometimes, the biometric information captured from a person is stored and processed in raw form, which allows for the recognition of the source from which it comes without special knowledge; for example, a photograph of a face, a photograph of a fingerprint, or a voice recording. Other times, the raw biometric information captured is processed in such a way that only certain characteristics or traits are extracted and saved as a biometric template.

Biometric systems are closely linked to a person, as they can utilize a specific unique property of an individual for identification. Each individual has unique fingerprints that display specific characteristics that can be measured to determine whether a fingerprint corresponds with a registered sample.

Biometric data has the particularity of being produced by the body itself and characterizes it definitively. Therefore, they are unique, permanent, or definitive over time, and the person cannot rid themselves of them; they can never be changed, not even with age, creating issues of liability in the event of compromise-loss or intrusion into the system. Unlike a password, in the event of loss, they cannot be changed.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

22/60

The definition of biometric data refers to “technical processing,” without specifying, except to note that the purpose of such processing must be to identify a person.

To be considered biometric data in the sense of the GDPR, the processing of unprocessed data, such as the physical, physiological, or behavioral characteristics of a natural person, must involve a measurement of those characteristics. Therefore, from the concept, one must not lose sight of:

- The nature of the data: data relating to the physical, physiological, or behavioral characteristics of a natural person;
- The means and forms of processing: data “obtained from a specific technical processing”; which differentiates them, for example, from images of a person that appear in a surveillance system, which cannot be considered biometric data unless they have been technically processed in a specific manner to contribute to the unique identification of that person.

They must be subject to “specific technical processing.” According to WP80 of the GT29, adopted on

01/08/2003 (hereinafter, "WP 80 of GT 29"), the processing of these data is carried out through biometric systems that are: "applications of biometric technologies that allow for automatic identification and/or authentication/verification of a person. Authentication/verification applications are commonly used for various tasks in very different fields and under the responsibility of a wide range of different entities."

The mention included in Article 4.14 of the GDPR as biometric data intended to "allow" can be understood as identification, while "confirm" refers to verification.

For a better understanding, the concepts of authentication/verification and identification are described. The Opinion 3/2012 on the evolution of biometric technologies dated 27/04/2012 from Working Group 29 stated:

“-Biometric identification: the identification of an individual by a biometric system is normally the process of comparing their biometric data (acquired at the time of identification) with a series of biometric templates stored in a database (i.e., a one-to-many matching process).

-Biometric verification/authentication: the verification of an individual by a biometric system is normally the process of comparing their biometric data (acquired at the time of verification) with a single biometric template stored in a device (i.e., a one-to-one matching process).”

With slight nuances, the concepts are mentioned in the “White Paper on Artificial Intelligence” by the European Commission, dated 19/02/2020, referring to facial images:

“In relation to facial recognition, ‘identification’ is understood as the comparison of a person's facial image template with many other templates stored in a database to determine if their image is stored in it. ‘Authentication’ (or ‘verification’), on the other hand, usually refers to the search for matches.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

23/60

between two specific templates. It allows for the comparison of two biometric templates that, in principle, are assumed to belong to the same person; thus, the two templates are compared to determine if the person in the two images is the same. This procedure is used, for example, in automated border control gates employed in airport border checks.”

The Guidelines 5/2022 from the European Data Protection Board (EDPB) regarding the use of facial recognition in the context of law enforcement (see Version 2.0, dated 26/04/2023), in section 10, states:

“As with any biometric process, facial recognition can serve two distinct functions:

- The authentication of a person in order to verify that the person is who they claim to be. In this case, the system compares a pre-recorded biometric template or sample (for example, stored on a smart card or a biometric passport) with a single face, such as that of a person presenting themselves at a checkpoint, to verify if it is the same person. Therefore, this function is based on the comparison of two templates. It is also referred to as 1-to-1 verification.
- The identification of a person in order to locate them among a group of individuals, within a specific area, in an image or in a database. In this case, the system must process each captured face to generate a biometric template and then check if it matches a known person in the system. Thus, this function is based on the comparison of a template with a database of templates or samples (reference database). It is also referred to as “one among many” identification. For example, it can relate a record of personal names (surnames, first name) to a face if the comparison is made with a database of photographs associated with surnames and first names. It may also involve tracking a person through a crowd, without necessarily establishing a link to the civil identity of the person.”

The aforementioned Guidelines 05/2022, in section 12, indicate that the concept of biometric data encompasses both “authentication” and “identification,” and although they are distinct concepts, in both procedures, data aimed at uniquely identifying a natural person is processed, thus both are included in the concept of “data processing,” and more specifically, they are processing of special categories of personal data.

Regarding the consideration that the respondent gives to its biometric facial recognition system, as

inferred from the content referred to in FACT FOUR/3/3.5/3.5.3/ where it is considered as verification/authentication, one against one, it is evidenced that the comparison between the biometric data of facial recognition used by the respondent is that of identification, or 1:N, one versus N, or also referred to as one to many.

This results because the acquired/incoming data through the reading of the face each time access is gained or exited for clocking in would perform a comparison process with the template data, but not with A SINGLE BIOMETRIC TEMPLATE STORED ON A DEVICE, but with all templates of all employees - including that of the claimant - all subject as employees to the respondent's time control system, and previously collected to be used, stored, ALL in the centralized database of the respondent itself, proceeding not to a matching/comparison 1:1, or one against.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

24/60

one, but 1, the one presented at that moment, in front of N 1 versus several (all those stored in the database of the defendant), to find its own previously registered one, without the employee having any storage device as it seems to suggest.

In both cases, whether verification-authentication or identification, the facial recognition techniques used are based on an estimated match between templates: the one being compared and the reference one(s). From this perspective, they are probabilistic techniques: the comparison deduces a greater or lesser probability that the person is indeed who is to be authenticated or identified; if this probability exceeds a certain threshold in the system, defined by its user or developer, the system will understand that there is a match.

The data of an identified natural person is that this person is distinguished or isolated from a group of people. Unique may refer to the fact that biometric data has such particularities that it can unambiguously identify an individual. In this way, a unique identifier can be associated with other additional attributes or personal data.

It is advanced, as will be indicated, that the biometric template, for the purpose of identification or authentication, is a personal data per se and a unique identifier.

The purpose of the processing: the data must be used for the purpose of uniquely identifying a natural person.

Biometric characteristics are subjected to a technical processing through which a person is recognized from an image or photograph, which includes for its implementation a chronological process contained in all biometric data processing: its capture or data registration with subsequent storage or processing and the phase of comparison or matching.

On the other hand, Recital 51 of the GDPR refers to the non-systematic consideration of photographs as a special category of data processing, as they are only included in the definition of biometric data when a specific technical processing means is applied that "allows or confirms the unique identification of that person." In any case, contrary to the aforementioned recital, whether applying a specific technical processing means to the photograph, or with the face registration made expressly (for example, with an express appointment of CB for the exposure of the face and data collection), we would be dealing with biometric data.

Any biometric system for a purpose, in this case, labor control of working hours, in order to be used, must first register in the system through the capture a series of biometric parameters (the face in this case), as the aim is to perform processing on those facial parameters to identify the person each time they subsequently enter and exit through the access point.

The operating mechanism of the system consists of capturing the image of the face and creating the template, which is stored so that when access is attempted in this case, to the workplace, in the space determined by the employer, it detects the image of the face and is processed again, obtaining a template and comparing it with the one stored. The physical space and support in which the template can be stored to implement the operational technique may vary, from being stored in a device that only...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
25/60

is stored in the hands of the person, maintained under their exclusive control by carrying the user (e.g., a card) which is not the case here, to a centralized database in the systems of the responsible party, as in this case.

Furthermore, in this case, alongside the biometric templates stored in the management software, they are linked to the IDs of the users (employees of the company) in a specific table for biometric data, from which, each time a check-in occurs when entering and exiting the workplace, a record of attendance control is generated, which is the intended purpose of the respondent.

In the so-called registration process, there are the following phases:

- Registration of biometric parameters. This encompasses all processes carried out in a biometric system in order to extract biometric data from a biometric source and link this data to an individual. In this case, the face. The facial recognition software sees the face and converts these measurements into a numerical code, hash, or template.

This numerical code, hash, or template is what is stored for comparison when entering or exiting the area where the facial recognition reader is located, which records the entry or exit of, in this case, access to the respondent's company, and serves as a control point used for the timekeeping of the workday. Therefore, facial recognition techniques require a certain level of cooperation from the employee since the camera must be positioned in front of the face while the photo is taken.

- Processing: Creating a template with the personal characteristics of the captured parameters.

- Enrollment: of the processed template, storing it in an appropriate storage medium. Once the enrollment is complete, the system can begin to be used.

Thus, the in-person capture in front of the device results in obtaining an image, from which the characteristics are extracted through the algorithm, which is part of the software of the respondent's device.

Algorithms, it is worth noting, come from the manufacturer or designer of said device and are considered an additional risk factor for processing, as the lack of transparency, accuracy rate, its auditing, and certifying entities can be factors to consider.

These characteristics are the measurements of positioning and relative reference measurements (nodal points: distance between the eyes, shape of cheekbones...) that are collected from each image of each individual and serve as the natural starting point for the automatic processing and recognition of individuals. The extraction of characteristics provides information to distinguish between the faces of different people based on their geometric or photometric variations.

The raw image of the biometric characteristics, in this case, the faces, is reduced, transforming but retaining highlighted discriminated information that is essential for the recognition of the person. These extracted characteristics are maintained in a biometric template, which is a form of reduced mathematical representation of the

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
26/60

original characteristic, referred to here by CB as "hash." The reference template is stored for comparison, in this case in a database where those of all employees are kept.

In the final phase, a biometric sample—such as the face—presented to the sensor will be compared with a previously recorded/stored template. The phases align with the enumeration of what could be a data processing operation (collection, storage, use).

As for the argument that it only identifies workers belonging to the group of previously registered employees, this is not a reason to not consider it biometric data, which is aimed at identifying individuals with data generated from the extraction of their biometric characteristics.

Furthermore, the definition of biometric data includes that through specific technical processing, it "allows or confirms" "the unique identification" of that person. Therefore, both identification and authentication must be unique, referring to the identification that occurs of the person. Unique identification, on the other hand, goes beyond whether the data pertains to an identified or identifiable individual. Identified individual data means that this person is distinguished or isolated from a group of people. Unique can refer to the fact that biometric data has such particularities that they can unambiguously identify an individual. In this case, unique identification occurs through the registration of each employee's facial image, associating it with a user ID stored in the database of the respondent, which allows for the identification of each employee.

According to the information provided by CB, when passing through the space that captures the facial recognition image, placed for the purpose of recording entry and exit times, "a number with many digits" has been generated "through the hash function (application of an algorithm) that provides a unique value." This means that the biometric information collected, in this case, the facial image, is processed following procedures defined in standards, and the result of that process is stored in data records referred to as signatures, patterns, or "templates." These patterns numerically record the physical characteristics that allow for the differentiation of individuals. In the image capture space, the device's software compares the offered pattern when presented with the stored one, for the purpose of recording the workday.

In this case, although the entire facial image is not stored, but rather a template, all templates of all employees, each distinct, are capable of uniquely identifying each employee by confronting the image capture space when accessing with the rest of the existing stored ones. The functions contained in the algorithm allow for the extraction of characteristic points for subsequent comparison with a database associated with the previously stored set of employees, being able to identify its holder among all the templates, dealing with personal data based on the processing of the fingerprint, uniquely identifying that person.

Technically, the biometric template against which the sample is compared is the product of a measurement that uniquely and exclusively identifies the individual.

The biometric data of each user, acquired at the moment of capture and recorded, are subjected to the technical procedure that converts the image, the format, into a biometric sample and through the algorithm into a biometric template, being stored, so that with the samples introduced by placing the finger at the access points, it identifies through.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

27/60

of the saved model, among all the templates, without a doubt, to its holder, what it would do, would be, without a doubt, to uniquely identify that person.

The use of the face is not only capable of validating identity accurately, but it also contains unique information about individuals. The software algorithm, based on the biometric sample, extracts biometric features, reduces and transforms that sample into labels or numbers, constituting a mathematical representation of the original biometric feature, which is the biometric template. The template is stored for comparison in the final phase in which, with the biometric sample—in the reader—and with the previously recorded template, it is uniquely identifying the employee each time they enter or exit by placing their face in front of the reader, which is why it is considered that the data falls within the scope of special data, due to being a unique identification.

In this case, it cannot be said that it does not involve information linked to personal data of an identified person in each access record, since, moreover, it should be noted that if they did not allow for the unequivocal identification of the employee, the time registration that it aims for would not occur.

It is thus established that CB processes biometric personal data of its employees, in this case with the purpose of time registration that allows for the identification of each employee when entering or exiting their workplace, recording the daily work hours, technical and organizational instruments provided by the defendant as responsible for such processing.

III Object and purpose of the processing

The purpose of evaluation in this procedure is the regulatory adjustment that is analyzed regarding the biometric facial recognition system that CB implemented with the aim of processing the data of the employees of its entity for the registration of working hours, access, and exit in the course of daily employment.

Within CHAPTER IV of the GDPR, its Section 1 addresses the general obligations of the data controller and the data processor. To this end, Article 25 of the GDPR states:

“1. Taking into account the state of the art, the cost of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity that the processing entails for the rights and freedoms of natural persons, the data controller shall implement, both at the time of determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures, such as pseudonymization, designed to effectively apply the principles of data protection, such as data minimization, and to integrate the necessary safeguards into the processing, in order to comply with the requirements of this Regulation and protect the rights of the data subjects.

2. The data controller shall implement appropriate technical and organizational measures to ensure that, by default, only personal data that are necessary for each specific purpose of the processing are processed. This obligation shall apply to the amount of personal data collected, the extent of its processing, its retention period, and its accessibility. Such measures shall ensure in particular that,

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
28/60

by default, personal data shall not be accessible, without the intervention of the individual, to an indeterminate number of natural persons.”

This implies that in the design of processing operations, these obligations of data protection by design and by default (PDD) must be applied, “being applicable throughout the entire processing cycle, and being mandatory for processing systems that already existed before the GDPR came into force” (Guidelines 4/2019 on Article 25. Data protection by design and by default, adopted on 20/10/2020 by the European Data Protection Board).

In the same vein: “37... The nature, scope, and context of the processing operations, as well as the risk, may change during the course of processing, which means that the controller must reevaluate its processing operations by periodically reviewing and assessing the effectiveness of the measures and safeguards it has decided to adopt.

38. The obligation to maintain, review, and update the processing operation, as necessary, also applies to existing systems. This means that legacy systems designed before the GDPR came into force must be reviewed and maintained to ensure that measures and safeguards are applied that effectively uphold the principles and rights of data subjects, as explained in these Guidelines.”

Chapter III of Royal Decree-Law 8/2019, of 8/03, on urgent measures for social protection and combating labor precariousness in working hours included a reform aimed at regulating the recording of working hours, as a way to combat labor precariousness, and specifically Article 10 amends Royal Legislative Decree 2/2015, of 23/10 (ET), Consolidated Text of the Workers' Statute, (ET) to regulate in its Article 34.9 the recording of working hours, for the purpose of ensuring compliance with limits regarding working hours, creating a legal security framework for both workers and companies, and enabling control by the Labor and Social Security Inspectorate. This employer obligation is imposed with a specific purpose, favorable to the worker, as reiterated in various sections of the Preamble. The regulation only mentions the aforementioned obligation, corresponding to entities to implement the manner in which it will be carried out, which should respect the regulatory framework. The indicated article states:

“The company shall guarantee the daily recording of working hours, which must include the specific time of commencement and conclusion of the working day for each worker, without prejudice to the

flexible working hours established in this article.”

Since this implementation, the recording of working hours is a legal obligation imposed on employers, a legal obligation, that of the recording, not that of the recording through facial recognition with biometric registration and reading, and the respondent has stated that, nevertheless, it had been using it since before this date, specifically since 2016.

In this case, such compliance was imposed through the biometric facial recognition system, which involves the processing of personal data for the purpose of verifying the daily recording of working hours by confirming the “specific time of commencement and conclusion of the working day for each worker.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

29/60

CB, as the data controller and employer entity, was the one that decided from the outset, the exact date of which is unknown, to use the registration and storage of data generated by facial recognition for the purpose of recording working hours. This is evidenced in the proven facts through the Inspection Service, which provided a copy of the employee management system.

The entity SAICA acquired the majority of the shares of the defendant entity on 07/07/2022, after the biometric facial treatment system had been implemented and was still operational. The entity CB remained active, although it became part of the SAICA GROUP of companies, which, following its acquisition, promoted the development of decisions that could affect its data protection policy, as evidenced, among others, by the project to abandon the biometric facial treatment system adopted on 19/10/2022. The enforceability of the obligations regarding data protection to CB stems from the fact that its failure to comply can be considered established and attributable, at least during the processing of the claimant's data, through the system it itself imposed, as the data controller and maintaining its legal personality, which implies full accountability for its responsibility in the actions that are reproached and attributed to said entity.

The obligation to record the daily working hours of employees does not arise from a contract but from a law, the Workers' Statute, which does not specify the means or methods by which it should be carried out. Given that this registration of personal data for that purpose intersects with a fundamental right of its holders, namely, the protection of their personal data, any interference with the same must be expressly provided for in a law.

The analysis of the legitimacy of biometric processing must be based on a legitimizing basis, but also on whether the processing is necessary, proportional, and can be carried out with a low risk to the rights and freedoms of the data subjects, considering the regulatory standard that frames the obligation.

IV Biometric Data Processing: Legitimacy

Biometric data, classified as “special category” data, in Article 9 of both the GDPR and the LOPDGDD, are data whose use may pose significant risks to fundamental rights and freedoms, and therefore, in principle, their processing is prohibited under Article 9.1 of the GDPR, which states:

“The processing of personal data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs, or trade union membership, and the processing of genetic data, biometric data aimed at uniquely identifying a natural person, data concerning health or data concerning a natural person's sex life or sexual orientation is prohibited.”

A similar prohibition is contemplated in Recommendation CM/REC (2015)5, from the Committee of Ministers of the Council of Europe to member states regarding the processing of personal data in the employment context. Specifically, Principle 18 of this Recommendation establishes the following:

“18.1. The collection and subsequent processing of biometric data should only be undertaken when it is necessary to protect the legitimate interests of employers, employees, or third parties, only if there are no other less intrusive means available, and only if accompanied by the appropriate safeguards provided for in Principle 21. 18.2. The

C/ Jorge Juan, 6

www.aepd.es
28001 – Madrid
sedeagpd.gob.es
30/60

The processing of biometric data must be based on scientifically recognized methods and must be subject to strict security and proportionality requirements.” Regarding the exceptions that may apply in the labor context, which is the one affected here, Article 9 of the GDPR states:

“2. Paragraph 1 shall not apply when one of the following circumstances applies:

...

b) the processing is necessary for compliance with obligations and the exercise of specific rights of the data controller or the data subject in the field of labor law and social security and protection, to the extent that it is authorized by Union law or the law of the Member States.”

These are cumulative requirements along with the legitimacy provided in Article 6.1 of the GDPR, which represent an additional guarantee in the processing of data belonging to its holder, taking into account that if the objectives can be achieved without processing personal data, this route will be preferable and will mean that no data processing is necessary, and subsidiarily, that the collection of data is necessary for the established or intended purpose and, if so, that it is proportional.

The Article 29 Working Party, in its Opinion 3/2012 on the evolution of biometric technologies, indicates that “When analyzing the proportionality of a proposed biometric system, it is necessary to first consider whether the system is necessary to respond to the identified need, that is, whether it is essential to meet that need, and not just the most appropriate or cost-effective. A second factor to consider is the likelihood that the system will be effective in addressing the need in question in light of the specific characteristics of the biometric technology to be used. A third aspect to weigh is whether the resulting loss of privacy is proportional to the expected benefits. If the benefit is relatively minor, such as increased convenience or slight savings, then the loss of privacy is not appropriate. The fourth aspect to evaluate the adequacy of a biometric system is to consider whether a less invasive means of privacy would achieve the desired end.”

However, when it comes to biometric data, in addition to lifting the prohibition on its processing, it must comply with one of the legal bases legitimizing the processing contained in Article 6.1 of the GDPR.

The fundamental right to data protection, as provided in Article 18.4 of the Spanish Constitution (CE), is based, in this case, on the essential principle that the processing of data belonging to its holder “shall only be lawful if at least one” of the conditions set out in Article 6.1.a) to f) of the GDPR is met, starting from the premise that any processing of such data restricts the rights of its holder simply by the fact of undergoing such processing, from which point they will increasingly be identified by this mechanism.

The respondent refers in its information to the respondent regarding the processing of labor data, stating that the legitimacy of the processing of its data, which included time control through “fingerprint capture,” “images: photograph-facial scan,” which in the procedure has been verified to be the biometric facial recognition system, is based on the compliance and development of the employment relationship, which would fall under Article 6.1.b) of the GDPR. However, referring exclusively to the processing of biometric data of the

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
31/60

Facial recognition for labor control, the respondent did not express any aspect when questioned about it during the transfer of the claim. It must be taken into account that, according to Article 9.2.b) of the GDPR, it would be:

- that it is “the processing necessary for compliance with legal obligations and the exercise of specific rights of the data controller or the data subject in the field of labor law and social security and protection”
- “to the extent that such is authorized by the Member States,” which is not indicated to exist in the

Spanish legal system as such an authorizing provision.

- "or a Collective Agreement also in accordance with the law of the Member States, which establishes adequate guarantees for the respect of fundamental rights and the interests of the data subject."

Thus, it must also be agreed that the legal obligation for the daily recording of working hours does not derive from obligations assumed between the parties but from legal regulations contained in Article 34.9 of the Workers' Statute (ET).

For control through the daily recording of each employee's working hours, it is necessary to process their data, with a different analysis of the necessity and proportionality in the chosen means, for which it could be considered that there are alternative systems that would distance the necessity and proportionality of the facial recognition processing for this purpose, which would not fit this strict necessity requirement for executing the contract.

It should be considered that, in this case, the use of fingerprint recognition (RF) has been abandoned in favor of a card system, which may be practical evidence that another less intrusive system in rights and with fewer inherent risks could have been possible, arising from the very nature of its use for an ordinary activity such as time control, given the size of the company in which there are no special conditions or circumstances that would advise such a means in the respondent company, which uses automated measured bodily means for such purposes.

In conclusion, although the Workers' Statute (ET) provides for the possibility that the employer adopts surveillance and control measures to verify compliance with labor obligations of their workers (Article 20.3 of the ET), in the case of time control, the regulation establishes the need to prepare a daily record of working hours. However, the regulation does not determine the specific mechanism to be used for the recording of working hours, nor does it foresee any express authorization for the use of special categories of data and, specifically, biometric data.

In any case, in these treatments, one must be very cautious in the assessment made regarding whether such requirements are met, as special data is being processed.

V Data Protection Impact Assessment (DPIA)

Furthermore, the proactive responsibility system implemented by the GDPR, focused on the continuous management of potential risks associated with processing, imposes on data controllers the obligation to analyze what data they process, for what purposes, and what types of processing they carry out, relating the potential risks to which they are exposed and to

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

32/60

From there, decide what measures to take and implement to ensure compliance based on the detected and assumed risks. It has already been mentioned in the legal basis III that the purpose of the processing must be complemented with a Data Protection Impact Assessment (DPIA).

The processing of biometric data through reading and recording tools presents high risks to fundamental rights and freedoms. Before implementing a data processing project, as long as it is likely to pose a significant risk to the rights and freedoms of individuals, as is the case here, it is necessary to audit its operation, not in isolation but within the framework of the specific processing in which it will be used. The Data Protection Impact Assessment (DPIA) is the tool that in the GDPR addresses the guarantee of compliance with this aspect of processing.

In this case, the various risks that may arise must be analyzed, including its technology, within the framework of an increasingly intensive use of this type of data. Its use, interoperability, and technological interconnection are likely to interfere with these fundamental rights and may raise questions about its implementation.

The GDPR establishes the obligation to manage the risk that a processing operation poses to the rights and freedoms of individuals. This risk arises both from the very existence of the processing and from its technical and organizational dimensions. The risk arises from the purposes of the processing and its nature, as well as from its scope and the context in which it operates.

The use of biometric data and, in particular, the facial recognition procedure entails greater risks for

the rights of the data subjects. It is essential that the use of these technologies is carried out in full compliance with the principles of legality, necessity, proportionality, and data minimization established in the GDPR. While the use of these technologies may be perceived as particularly effective, the controllers must, first and foremost, assess the impact on fundamental rights and freedoms and consider less intrusive means to achieve their legitimate purpose of processing.

The "risk-based approach" is developed in the "Statement on the role of a risk-based approach in data protection legal frameworks WP218" of the Article 29 Working Party, WP218, and is not a novel concept within the framework of data protection.

The management of risk to rights and freedoms aims to study the impact and the likelihood of causing harm to individuals, at an individual or social level, as a result of personal data processing. In contrast, compliance risk management aims to provide the controller with a tool to verify the degree of compliance with the legally required obligations and provisions concerning a processing activity.

Therefore, prior to the risk management process and as a sine qua non condition for undertaking a processing activity, it is necessary to systematize the verification of regulatory compliance throughout the entire lifecycle of the processing. The complexity of the risk management process must be adjusted not to the size of the entity, the availability of resources, the specialty or sector of the entity, but to the possible impact of the processing activity on the data subjects and to the inherent difficulty of the processing.

Article 35 of the GDPR establishes the obligation to have a Data Protection Impact Assessment (DPIA), stating:

"1. When it is likely that a type of processing, in particular if it uses new...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

33/60

technologies, by their nature, scope, context, or purposes, pose a high risk to the rights and freedoms of natural persons, the data controller shall carry out, prior to the processing, an assessment of the impact of the processing operations on the protection of personal data. A single assessment may address a series of similar processing operations that pose similar high risks.

2. The data controller shall seek the advice of the data protection officer, if appointed, when conducting the data protection impact assessment.

3. The data protection impact assessment referred to in paragraph 1 shall be required in particular in the case of:

a) systematic and comprehensive evaluation of personal aspects of natural persons based on automated processing, including profiling, and on which decisions are based that produce legal effects concerning the natural persons or that significantly affect them in a similar manner;

b) large-scale processing of special categories of data referred to in Article 9, paragraph 1, or of personal data relating to criminal convictions and offenses referred to in Article 10, or

c) systematic large-scale monitoring of a publicly accessible area.

4. The supervisory authority shall establish and publish a list of the types of processing operations that require a data protection impact assessment in accordance with paragraph 1. The supervisory authority shall communicate these lists to the Committee referred to in Article 68.

5. The supervisory authority may also establish and publish a list of the types of processing that do not require data protection impact assessments. The supervisory authority shall communicate these lists to the Committee.

6. Before adopting the lists referred to in paragraphs 4 and 5, the competent supervisory authority shall apply the consistency mechanism provided for in Article 63 if those lists include processing activities related to the offering of goods or services to data subjects or the monitoring of their behavior in several Member States, or processing activities that may substantially affect the free movement of personal data within the Union.

7. The assessment shall include at least:

a) a systematic description of the envisaged processing operations and the purposes of the

processing, including, where applicable, the legitimate interest pursued by the data controller;
b) an evaluation of the necessity and proportionality of the processing operations in relation to their purpose;
c) an assessment of the risks to the rights and freedoms of the data subjects referred to in paragraph 1, and

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
34/60

d) the measures planned to address risks, including guarantees, security measures, and mechanisms that ensure the protection of personal data, and to demonstrate compliance with this Regulation, taking into account the rights and legitimate interests of the data subjects and other affected individuals.

8. Compliance with the approved codes of conduct referred to in Article 40 by the respective controllers or processors shall be duly taken into account when assessing the impact of the processing operations carried out by such controllers or processors, particularly for the purposes of the data protection impact assessment.

9. Where appropriate, the controller shall seek the opinion of the data subjects or their representatives regarding the intended processing, without prejudice to the protection of public or commercial interests or the security of the processing operations.

10. When the processing based on Article 6(1)(c) or (e) has its legal basis in Union law or in the law of the Member State applicable to the data controller, such law regulates the specific processing operation or set of operations in question, and a data protection impact assessment has already been carried out as part of a general impact assessment in the context of the adoption of such legal basis, paragraphs 1 to 7 shall not apply unless Member States consider it necessary to carry out such assessment prior to the processing activities.

11. If necessary, the controller shall examine whether the processing is in compliance with the data protection impact assessment, at least when there is a change in the risk posed by the processing operations.

In furtherance of paragraph 4, the Director of the AEPD approved a non-exhaustive, indicative list of types of processing that require a data protection impact assessment, stating: "When analyzing data processing, it will be necessary to conduct a DPIA in most cases where such processing meets two or more criteria from the list set out below, unless the processing is included in the list of processing that does not require a DPIA referred to in Article 35.5 of the GDPR. The list is based on the criteria established by the 'GUIDELINES ON DATA PROTECTION IMPACT ASSESSMENT (DPIA) AND DETERMINING WHETHER PROCESSING "IS LIKELY TO RESULT IN HIGH RISK" FOR THE PURPOSES OF THE GDPR,' last revised and adopted on 4/10/2017, WP 248 rev.01 of GT 29, which complements it and should be understood as a non-exhaustive list:

"4. Processing involving the use of special categories of data referred to in Article 9.1 of the GDPR... or inferring information about individuals related to special categories of data.

5. Processing involving the use of biometric data for the purpose of uniquely identifying a natural person."

9. Processing of data of vulnerable subjects..."

In the same Guidelines, it is noted:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
35/60

"To provide a more concrete set of processing operations that require a DPIA due to their inherently high risk, taking into account the specific elements of Article 35, paragraph 1, and Article 35, paragraph 3, letters a) to c), the list to be adopted at the national level under Article 35, paragraph 4, and recitals 71, 75, and 91, as well as other references in the GDPR to processing operations that

'likely entail a high risk', the following nine criteria should be considered:

"7. Data concerning vulnerable data subjects (recital 75): The processing of such data represents a criterion due to the increased power imbalance between the data subjects and the data controller, which implies that individuals may be unable to authorize or deny the processing of their data, or to exercise their rights. Vulnerable data subjects may include children (who are considered unable to consciously and responsibly deny or authorize the processing of their data), employees."

The DPIA is a necessary step for data processing, but as described, it is not the only requirement. It constitutes a prerequisite to which the other legal requirements for processing must be added. Among them, it is important to highlight, when it comes to processing special categories, the concurrence of an exception under Article 9.2 of the GDPR that lifts the prohibition of Article 9.1 of the same legal text for processing special categories of personal data (in this case, to lift the prohibition on the processing of biometric data), in addition to the legal basis of Article 6.1 of the GDPR. Furthermore, in any case, the fundamental principles of data processing set out in Article 5 of the GDPR must be complied with. WP 249, Opinion 2/2017 on data processing in the workplace, from the Article 29 Working Party (hereinafter, "WP 249 of the WP29") states that: "Regardless of the legal basis for such processing, a proportionality test must be carried out before its commencement to determine whether the processing is necessary to achieve a legitimate purpose, as well as the measures that must be taken to ensure that violations of privacy rights (...) are limited to the minimum."

Before implementing an RF system, the controller must assess whether there is another less intrusive system that achieves the same purpose.

Biometric processing presents not only high intrinsic risks to the rights and freedoms of data subjects, as evidenced in the successive opinions and guidelines that have been drafted on biometric systems by advisory and consultative bodies, the Article 29 Working Party, and since the entry into force of the GDPR by the European Data Protection Board, but also combines technological products used for its operation, which evolve very rapidly, undoubtedly influencing the essence of the processing operations, transferring exposure to multiple risks that require continuous reevaluations to which organizations must respond at both technical and organizational levels.

Among others, and without being exhaustive or intending to provide a closed list, some can be mentioned that are contemplated in Opinion 3/2012 on the evolution of biometric technologies from the WP 29 dated 27/04/2012:

- The definition of the size (amount of information) of the biometric template is a crucial issue. On one hand, the size of the template must be large enough to manage the...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

36/60

security (avoiding overlaps between different biometric data or identity substitutions), and on the other hand, it should not be too large in order to avoid the risks of reconstructing biometric data.

- Risks associated with the use of biometric data for identification purposes in large centralized databases, given the potentially harmful consequences for the affected individuals.

- It goes without saying that any loss of the qualities of integrity, confidentiality, and availability concerning the databases would be clearly detrimental to any future application based on the information contained in such databases, and would also cause irreparable harm to the stakeholders. For example, if the recorded data of an authorized person were associated with the identity of an unauthorized person, the latter could access the services available to the data owner without having the right to do so. The result would be identity theft, which (regardless of its detection) would undermine the reliability of the system for future applications and, consequently, limit its freedom.

- The transfer of the information contained in the database.

- The illusion can be created that identification through facial recognition is always correct; therefore, an analysis of the errors that may occur in its use should be included, performance evaluation metrics, false acceptance rate - the probability that a biometric system incorrectly identifies an individual or fails to reject an individual who does not belong to the group, and false rejection rate or false negative: no

match is established between a person and their own template. In the face of decisions that legally affect a person, any decision made based on this, such as in registration and time control systems, the deduction of remuneration based on registration with the system, should only be carried out safeguarding the rights and freedoms and the legitimate interests of the interested party, at a minimum the right to obtain human intervention from the responsible party, to express their point of view, and to contest the decision.

- Linking: a large number of online services allow users to upload an image to link it with the user profile. Facial recognition can be used to link profiles from different online services (through the profile image), but also between the online and offline worlds. It is not out of the question to take a photograph of a person on the street and determine their identity in real-time by searching these public profile images. Third-party services can also track profile photographs and other publicly available photographs to create large collections of images in order to associate a real-world identity with such images. This impact increases with the growing deployment of these technologies. Each individual may appear in one or more biometric systems.

- Security measures must be adopted regarding the processing of biometric data (storage, transmission, feature extraction and comparison, etc.) and especially if the data controller transmits that data over the Internet. Security measures could include, for example, the encryption of templates and the protection of encryption keys apart from access control and protection that makes it virtually impossible to reconstruct the original data from the templates. Additionally, the use of realistic masks or the use of photos to attempt to deceive the system, always in connection with advancements and the state of the art, taking into account that the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

37/60

The most effective biometric systems for recognizing a person are also the most potentially vulnerable. Furthermore, with the development of technologies, the risks identified at that time have significantly increased.

Regarding the guarantees to be implemented that must be included in the DPIA, the Guide "Data Protection in Employment Relationships" by the AEPD includes, as a reference, ten aspects that can be taken into account.

Additionally, the working document on biometrics, adopted on 01/08/2003 by the GT29, states that biometric systems related to physical characteristics that leave no trace (for example, the shape of the hand, but not fingerprints) or biometric systems related to physical characteristics that leave a trace but do not depend on the memorization of data held by a person other than the data subject (in other words, the data is not memorized in the access control device or in a central database) create less risk for the protection of the fundamental rights and freedoms of individuals. (Biometric data that is processed in a centralized manner can be distinguished from biometric reference data that is stored on a mobile device, where the conformity process is carried out on the card and not on the sensor, or when the sensor is part of the mobile device).

- It is generally accepted that the risk of reusing biometric data obtained from physical traces left by individuals unknowingly (for example: fingerprints) for incompatible purposes is relatively low if the data is not stored in centralized databases but is in the possession of the individual and is inaccessible to third parties. The centralized storage of biometric data also increases the risk of using biometric data as a key to interconnect different databases, which could allow for the creation of detailed profiles of an individual's habits both publicly and privately. Furthermore, the issue of the compatibility of purposes leads us to the interoperability of different systems that use biometrics. The standardization required for interoperability may result in greater interconnection between databases.

The respondent did not provide the Impact Assessment of the processing of biometric data that should have been conducted to carry out the processing it performed, which is capable of identifying each employee, as it has its staff stored and when it presents the sample, it checks it against all existing ones, fully identifying its holder through the samples stored in the database. As previously noted, such

processing of this type of data occurs.

In accordance with the available evidence, it is considered that CB violated the provisions of Article 35 of the GDPR, and this infringement is attributed to it.

VI Response to the allegations regarding the infringement of Article 35 of the GDPR

Regardless of the fact that the other allegations have been addressed in the specific section that may relate to them, such as in the determination of the sanction related to proportionality, here they are limited to those related to the specified infringement attributed under Article 35 of the GDPR.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

38/60

Regarding the allegation made against the proposed resolution, concerning the failure to comply with the principle of proactive responsibility by not documenting the reasons for not conducting a DPIA, the respondent states that it has already presented its considerations regarding the entry into force of the GDPR and the implementation of the system in 2016, and that the burden of proof lies with the Administration, given that the presumption of innocence is guaranteed by the Spanish Constitution. It concludes that it did not conduct the DPIA because "in 2016 this obligation was not contemplated in the regulations."

Regarding the burden of proof, when the GDPR imposes obligations on the data controller, specifically in this case, related to the documentation regarding the non-necessity of conducting a DPIA for the processing of labor data with a facial recognition system, it must be indicated that it is the data controller who must demonstrate compliance with such obligations.

This derives from what is stated in Article 5.2 of the GDPR, which requires that data controllers must demonstrate compliance with their obligations under the GDPR, including the effectiveness of the measures, by adequately documenting all decisions made in order to be able to demonstrate it, in accordance with Recital 74 of the GDPR. Therefore, the fact that the respondent considers that it does not need to carry out a DPIA does not diminish the general obligation of data controllers to apply measures to adequately manage the risks to the rights and freedoms of the data subjects. In practice, this means that data controllers must continuously assess the risks created by their processing activities in order to identify when it is likely that a type of processing entails "a high risk to the rights and freedoms of natural persons." Although a processing operation corresponds to the cases where a DPIA must be conducted, a controller may not consider that such processing "probably entails a high risk." In these cases, the controller must justify and document the reasons for not conducting a DPIA and include/register the opinions of the data protection officer.

The opposite would imply disregarding that the GDPR pursues as objectives a broad and reinforced protection of the right to data protection in the rights of data subjects as well as the obligations of data controllers, as deduced from Recital 11 of the GDPR: "The effective protection of personal data in the Union requires that the rights of data subjects and the obligations of those who process and determine the processing of personal data are strengthened and specified."

In any case, and in the examined case, it has been perfectly proven, based on the established facts and what has been acknowledged by the respondent itself, that it neither conducted a prior analysis to determine whether it needed to conduct a DPIA starting from May 2018, nor did it conduct a DPIA, thus undermining the presumption of innocence.

What it states in its defense, regarding the fact that the risks have not changed, are mere statements from the respondent without having conducted an analysis on that particular matter, lacking clear elements and documents to support it.

Regarding the allegations related to the non-requirement of conducting a DPIA because in 2016, when the system was implemented and the biometric personal data of the fingerprint began to be used, the GDPR was not in force. Therefore, it was not in effect.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
39/60

this regulation when the events occurred, and an attempt is made to apply a regulation retroactively. As an example to defend its thesis, it cites the ruling of the National Court, Administrative Litigation Chamber, Section 1 of 14/05/2021, rec. 115/2020.

In this regard, it should be noted:

- The aforementioned ruling declares the nullity of the sanction imposed by the AEPD for a very serious infringement classified in Article 5.1.f) of the GDPR (duty of confidentiality in the processing of data) considering that a regulation that was not applicable when the sanctioned events occurred, 13/04/2018, such as the GDPR, was applied.

It is worth citing from it:

“Fourth legal basis”: “Article 99 of the GDPR establishes: ‘1. This Regulation shall enter into force twenty days after its publication in the Official Journal of the European Union. 2. It shall apply from 25 May 2018.’

And, in this sense, in Recital 171 of the cited GDPR, it states: ‘Directive 95/46/EC must be repealed by this Regulation. Any processing already initiated on the date of application of this Regulation must comply with this Regulation within two years from the date of its entry into force. When the processing is based on consent in accordance with Directive 95/46/EC, it is not necessary for the data subject to give their consent again if the manner in which consent was given complies with the conditions of this Regulation, so that the controller may continue such processing after the date of application of this Regulation. Decisions of the Commission and authorizations of the supervisory authorities based on Directive 95/46/EC remain in force until they are amended, replaced, or repealed.’

Therefore, the GDPR entered into force 20 days after its publication in the Official Journal of the European Union, that is, on 24 May 2016; however, it will only be directly applicable and mandatory in all its elements in each Member State from 25 May 2018, thus allowing Member States and their respective Supervisory Authorities a period of 2 years for preparation, application, and interpretation of the various rights and obligations it establishes.”

The ruling indicates that, to such events, not only was the GDPR applied, but also the LOPDGDD which came into force on 6/12/2018, “therefore a regulation that was not applicable when the sanctioned events occurred was applied. We must add that the aforementioned regulation could have been applied if it had been more favorable... the retroactive application of the more beneficial regulation must be made by determining which provision is more favorable, through the contrast between both, previous and subsequent, considered globally...”. And such contrast does not exist in the contested resolutions, which do not even mention Organic Law 15/1999, of December 13, and in which the GDPR and Organic Law 3/2018, of December 5, are applied as if it were the regulation that was in force when the sanctioned events occurred, in April 2018.”

As can be seen, first of all, it is about examining the application of the preferential current regulation, or if it were, more beneficial, at the time the events occurred, which in principle should be the one in force at the time the classified event took place. However,

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
40/60

In this case, the respondent completely excludes the application of the GDPR, adding that the conduct occurred before the GDPR came into effect, without explaining what it means by such a statement.

And, in any case, the facts constituting the infringement that have been proven occurred from the entry into force of the GDPR, being this regulation fully applicable to them.

The complaint considers the processing carried out with the claimant's data for labor purposes, as the claimant provided services to the respondent during a period in the year 2023, being indisputable that

both he and the other employees were subject to biometric facial recognition processing for daily time control. Therefore, it is irrefutable that various operations of different scope were carried out for this purpose on the data of the employees of the respondent. Additionally, it should be noted that when the claimant ceased his employment relationship on 12/09/2023, the other employees continued to have their data processed for such purposes until the system change on 28/05/2023. Thus, it is also indisputable that data processing has been occurring through the use of the biometric facial recognition system established by the data controller, CB, after the entry into force of the GDPR, to which the respondent has not adapted its behavior, consisting of carrying out a DPIA, as determined by Recital 171 of the GDPR and inferred from the principles, guarantees, and obligations applicable in the aforementioned GDPR.

Article 35 of the GDPR indicates that before the start of these treatments considered high-risk for the rights and freedoms of natural persons, it is mandatory to carry out a detailed DPIA, with the information that describes it. This represents an essential tool for identifying and mitigating risks related to processing and establishing the necessity and proportionality of the processing among other elements included therein.

The statement on the role of a risk-based approach in data protection, adopted on 30/05/2014 by the Article 29 Working Party, indicates: "The so-called risk-based approach is not a new concept, as it is already well known under the current Directive 95/46/EC, especially in terms of security (Article 17) and the obligations of prior control by the DPA (Article 20). The legal regime applicable to the processing of special categories of data (Article 8) can also be considered the application of a risk-based approach: the strengthening of obligations arises from processing that is considered risky for the affected individuals. It is important to note that, even with the adoption of a risk-based approach, this does not weaken individuals' rights regarding their personal data. These rights must be as strong, even if the processing in question is relatively 'low risk'. Rather, the scalability of legal obligations based on risk addresses compliance mechanisms. This means that a data controller whose processing is of relatively low risk may not have to do as much to comply with their legal obligations as a data controller whose processing is high risk."

This obligation is independent of other obligations established in the aforementioned GDPR. It is clear that the regulation has evolved, and the model established at the level of the European data protection regulation aims to ensure a high level of protection for individuals concerning the processing of their personal data.

What the provision seeks through the requirement that such an evaluation be carried out prior to processing is precisely the assessment of potential high-risk situations.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

41/60

risk to the rights and freedoms of the data subjects and to avoid, as much as possible, the materialization of such risks. These risks also vary over time, as the circumstances in which the processing occurs (context, nature, scope, or purposes) do not remain unchanged over time. This consequently requires a continuous assessment which, concerning the DPIA, involves not only its completion but also the carrying out of periodic updates as the context, nature, scope, or purposes of the processing (including the type and number of personal data processed) change over time. As a result of the above, each time the system established by the defendant carries out the various processing operations necessary for time control, a series of data processing activities occur, to which the regulations provided for in the GDPR would apply. Therefore, even if the system were hypothetically operational before the GDPR came into force, the processing carried out from its entry into force requires the existence and completion of the prior impact assessment for such processing to comply with that regulation and the obligations set forth therein.

Regarding the allegation of the link provided by the defendant, located on the Agency's website, "frequently asked questions - GDPR - 2.10 Impact assessment: Do processing operations initiated before the application of the GDPR need to undergo a DPIA?", which includes the information: "No, the

mandate of the GDPR does not extend to processing operations that are already underway at the time it begins to apply. However, an Assessment should be carried out when changes in the risks that the processing implies have occurred in relation to the moment when the processing was initiated. This change in risks may arise, for example, from the fact that new technologies have begun to be applied to that processing, that the data is being used for purposes different from or additional to those decided at the time, or that more data, or different data, is being collected than was initially used for the processing."

It should be noted that all FAQs and Guides from the AEPD aim to be a means provided for the general public for awareness and knowledge of issues related to data protection, with a purely informative nature that does not delve into specific cases or situations. While it also serves Data Controllers and Data Processors, as many of them are directed at these entities attempting to facilitate compliance with regulatory management, this does not prevent the Data Controller from examining in the specific case of the specific processing they are carrying out what their obligations are regarding data protection.

Furthermore, if we look at the response given by the AEPD to this general question, it is not an absolute answer but is again related to the specific processing being carried out, in accordance with the vision implemented by the GDPR, which is based on the pillars of proactive responsibility (demonstrating compliance with the GDPR) and the risk-based approach to processing concerning the rights and freedoms of the data subjects. If for any reason, including other unforeseen causes not mentioned as examples in the response, the Data Controller observes that there have been changes in the risks, they must at least consider whether or not to carry out a DPIA, documenting the conclusion reached in any case.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
42/60

Regarding the fact that the processing of biometric data for labor control began in 2016, the defendant also stated during the Inspection that the data collected for this workday registration under Royal Decree-Law 8/2019, incorporated in the current Article 34.9 of Royal Legislative Decree 2/2015, of 23/10 (ET), Consolidated Text of the Workers' Statute (ET), remained stored in a historical Access file, and the templates were destroyed.

The Inspection Service also accessed the biometric data records in the defendant's management software, with registered employee data from April and May 2023, which would demonstrate the continued use of the system until its replacement by the new system on 29/05/2023. This makes it clear that the data, including that of the claimant who was linked by a contract for barely three months in 2023, were subject to registration for daily labor control using facial recognition tools, affecting the right to data protection not only of the claimant but of all employees, with continued processing during a long cycle of data existence, a time in which the obligation to be fulfilled by the defendant with the entry into force of the GDPR was not implemented, as evidenced by its absence.

Regarding the allegation that the obligation to carry out such a DPIA would be time-barred, it should be noted that the start of the limitation period for the infringement would not be computed from the day the system was implemented, in 2016 as the defendant claims, since such an act only determines its launch, with the processing activity developing from then on, integrated by various and repeated processing operations using specific technology until its replacement by another system based on time cards.

The absence of this obligation begins from the day the obligation stipulated in the GDPR should have been fulfilled, May 2018; the absence of compliance with this obligation has been maintained continuously and at least until the day the system of that type of registration was no longer used, 28/05/2023, since on the 29th and 30th, during the inspection visit, it was stated that such registered data no longer existed due to the implementation of the new time control procedure using cards starting from 29/05/2023.

That is to say, the lack of compliance with the enforceable obligation has persisted throughout that

period, estimating that each day the data processing is carried out without a DPIA, the risk to the rights and freedoms of the affected persons remains unassessed and without appropriate measures and guarantees based on its analysis, thus prolonging the infringement. We are, therefore, faced with a violation that persists over time as long as the obligation imposed by the GDPR is not fulfilled. This is also related to the fact that, despite being exposed by the specialized technical body of SAICA, the Data Protection Committee that the biometric system of CB should be replaced immediately from October 2023, its application will be extended until 28/05/2023. In this case, the aforementioned computation of the limitation period for the serious infringement considered under Article 35 of the GDPR would initially cover two years from 28/05/2023, considering that it would not be time-barred when the present procedure begins.

Likewise, regarding the allegation made in the proposal that the enforceability of carrying out the DPIA before processing should be counted from the date of entry into force of the GDPR, it should be indicated that this starting date for computation cannot be considered, since the processing carried out on the employees of the defendant continued, and this is evidenced at least until 28/05/2023, and the obligation for a prior DPIA has never been fulfilled after the entry into force of the GDPR. This express obligation cannot be cured or validated.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
43/60

by the passage of time as long as the treatment to which it serves as a basis has continued. The data has been subject to processing since 2016 until 28/05/2023, and although the obligation to carry out the DPIA arises from 25/05/2018, this obligation was not fulfilled, resulting in the claimant's complaint and confirming the persistence of its non-compliance.

Regarding the allegation in the proposal that there should be a distinction between the continuation in the use of the tool and the fact that the DPIA was not carried out prior to the "installation of the tool," it is not what is indicated in the proposal, but rather that the DPIA must be conducted chronologically "before the effective processing of the data," as expressly deduced from the content of Article 35 of the GDPR regarding the timing of its execution: "When it is likely that a type of processing, in particular if it uses new technologies, by its nature, scope, context, or purposes, poses a high risk to the rights and freedoms of natural persons, the controller shall carry out a DPIA prior to the processing...". In the same vein, the rest of the requirements regarding the guarantees of processing by design, Article 24.1 of the GDPR, would apply to the aforementioned processing, as risk management cannot be carried out in isolation, independently, or after the design and/or implementation of a processing activity. This processing by design, as a measure of proactive responsibility, must be applied by the controller prior to the commencement of processing, and also while it is being developed. It involves thinking in terms of data protection from the very moment a processing activity that involves the processing of personal data is designed, so that from the outset, its controllers must take organizational and technical measures that allow for the effective application of the principles of the GDPR.

Furthermore, the processing of data defined as indicated in Article 4.2 of the GDPR has no relation to the installation of a supporting system, since it is evidenced in this case that the data processing with the analyzed system was effective and carried out, and has transitioned to the protection regime established by a directly applicable regulation such as the GDPR. The defendant has continued to use in the daily labor control processing activity the biometric data of its employees, periodically carrying out such types of processing with facial recognition technology that involves various risks, so the computation of the start of the limitation period could not be counted from the installation of the system or from the start of its use.

Regarding the allegation that the risks have not varied since the establishment of the system in 2016, it should be noted that it is not a matter of connecting the risk in data processing solely with data security or with the damage that may occur, but with the risks to the fundamental rights and freedoms that the processing of data with these systems entails, inherent and specific risks, as well as others derived from its implementation in the specific case, which is what led to their characterization under the

GDPR as special category data. Additionally, it must be taken into account that the elements that are part of the data processing—the nature, scope, context, and purposes—also condition, in addition to the risks, the application of appropriate technical and organizational measures to ensure its processing.

In any case, as already expressed, the risks to the rights and freedoms of natural persons arising from processing vary or change over time, a matter that is undisputed. The categorical assertion by the defendant that the risks to the rights and freedoms of natural persons arising from processing have not varied since...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
44/60

that was implemented in 2016, lacks any support, any analysis, any justification.

Furthermore, the accreditation of the high risk affecting this treatment system has not only been contemplated in and since the first guidelines and opinions on this data in 2003, Working Document on Biometrics, dated 01/08/2023, continued in Opinion 3/2012 on the evolution of biometric technologies, adopted on 27/04/2012, and continues to be contemplated, as exemplified by the recent: Guidelines 5/2022 on the use of facial recognition technology in law enforcement adopted on 26/04/2023, or the Opinion of the EDPB of 11/2024 on the use of facial recognition to streamline passenger flow, adopted on 23/05/2024, which exemplifies the risks in the various ways of processing this type of data.

The inherent high risk in the processing of this type of data arises from the fact that biometric data, in this case, facial features, are unique and represent the same person. Moreover, it does not pose the same risks, for example, the use for identification purposes, in an uncontrolled environment, without the active participation of the data subjects, where the template of each face entering the monitoring area is compared with the templates of a broad cross-section of the population stored in a database, presenting specific risks that must be assessed on a case-by-case basis.

Therefore, without prejudice to the fact that the determination of risks corresponds to each data controller in relation to each of their specific processing activities, it seems clear that neither the technological level, nor the level and sophistication of possible attacks, nor their level of sophistication or the risks of fraud due to intrusion into the systems are the same now as they were eight years ago. On the other hand, knowing and identifying the threats regarding the use and the processing system that has evolved and continues to do so over time can help to understand and minimize the impacts. Regarding the assertion of the respondent entity that it was not a new system, it should be noted that such circumstance does not exempt compliance with the obligation provided once the regulation fully took effect after its entry into force. While it is true that the previous regulation did not contemplate such an obligation, which was focused on the type of data and not, as now, on the risks to the rights and freedoms of the data subjects arising from the processing, it is equally true that, once the GDPR applies, it has full efficacy. And that the respondent, due to the proactive responsibility provided in Article 5.2 of the GDPR, should not only have conducted and passed a DPIA as outlined in this procedure, but should also have determined whether the circumstances provided in Article 35 were present to carry out a DPIA, resulting in the need to verify whether in the case of the processing there was a high probability of risk to the rights and freedoms of individuals, in the terms indicated by the aforementioned article, even if the processing had begun before the application of the GDPR. And this must take into account that (i) risks are not static but dynamic, which can change in a processing over time, especially in this reality in which we find ourselves, and (ii) that they depend on the specific personal data processing being carried out and on the organization itself, purposes, and idiosyncrasy of the data controller, among other issues.

Finally, it should be added that not only have the risks to the rights and freedoms of the affected individuals changed, as shown by the fact that biometric data transitioned in the GDPR to

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid

to be part of the special category due to the inherent risks that its processing implies for the rights and freedoms of the data subjects. In addition, the automated technologies employed through algorithms, the lack of transparency of such means, as well as the assessment of necessity and proportionality in the establishment of the system, principles that are always applicable and must be complied with, should be added.

For all these reasons, these allegations cannot be addressed.

VII Exercise of the right of access and consequences of its lack of attention

The claimant exercised their right of access on 29/08/2022, establishing the obligations in Article 12 of the GDPR, which states:

1. The data controller shall take appropriate measures to provide the data subject with all information referred to in Articles 13 and 14, as well as any communication in accordance with Articles 15 to 22 and 34 relating to the processing, in a concise, transparent, intelligible, and easily accessible form, using clear and plain language, in particular any information specifically addressed to a child. The information shall be provided in writing or by other means, including, where appropriate, by electronic means. When requested by the data subject, the information may be provided orally, provided that the identity of the data subject is demonstrated by other means.
2. The data controller shall facilitate the exercise of the data subject's rights under Articles 15 to 22...
3. The data controller shall provide the data subject with information regarding its actions based on a request under Articles 15 to 22, without undue delay and, in any case, within one month of receiving the request...
4. If the data controller does not act on the request of the data subject, it shall inform them without undue delay, and at the latest within one month of receiving the request, of the reasons for not acting and of the possibility of lodging a complaint with a supervisory authority and of seeking judicial remedies.

This article establishes general obligations, included in Section 1 of Chapter III of the said Regulation, particularly relating to the principle of transparency stated in Article 5, paragraph 1, letter a) of the aforementioned Regulation. These general obligations fall on the data controller concerning the transparency of information and communications, as well as the modalities for exercising the rights of the data subject.

Article 15 of the GDPR, included in Section 2 of Chapter III, relating to information and access to personal data, completes the transparency framework of the GDPR by granting the data subject a right of access to their personal data and a right to information about the processing of such data.

Regarding the attention to the right of access requested on 29/08/2022, the aforementioned Article 15 of the GDPR indicates its content:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

“1. The data subject shall have the right to obtain from the data controller confirmation as to whether or not personal data concerning them is being processed and, if so, the right of access to the personal data and to the following information:

- a) the purposes of the processing;
- b) the categories of personal data concerned;
- c) the recipients or categories of recipients to whom the personal data have been or will be disclosed, in particular recipients in third countries or international organizations;
- d) where possible, the envisaged retention period for the personal data or, if not possible, the criteria used to determine that period;
- e) the existence of the right to request from the controller rectification or erasure of personal data or restriction of processing of personal data concerning the data subject, or to object to such processing;

- f) the right to lodge a complaint with a supervisory authority;
 - g) when the personal data have not been obtained from the data subject, any available information as to their source;
 - h) the existence of automated decision-making, including profiling, referred to in Article 22, paragraphs 1 and 4, and, at least in such cases, meaningful information about the logic involved, as well as the significance and the envisaged consequences of such processing for the data subject.
2. When personal data are transferred to a third country or to an international organization, the data subject shall have the right to be informed of the appropriate safeguards pursuant to Article 46 relating to the transfer.
3. The data controller shall provide a copy of the personal data undergoing processing. The controller may charge a reasonable fee based on administrative costs for any further copies requested by the data subject. When the data subject makes the request by electronic means, and unless otherwise requested, the information shall be provided in a commonly used electronic format.
4. The right to obtain a copy mentioned in paragraph 3 shall not adversely affect the rights and freedoms of others.”

Regulated by Article 15 of the GDPR, the right known as *habeas data* or *habeas scriptum* consists of the affected party being able to demand from the data controller a performance consisting of the mere display of their data.

This is an essential right in the matter that is enshrined in Article 8.b) and c) of Convention 108 of the Council of Europe. Furthermore, it is indisputable that the right of access constitutes an essential core of the right regulated in Article 18.4 of the Constitution - STC 292/2000 - and that it will help the applicant verify the legality of the relevant processing or exercise other rights.

The Guidelines 1/2022 of the European Data Protection Board on the rights of data subjects - right of access, version 2.1, adopted on 28/03/2023, state that “3. Under the GDPR, the right of access consists of three components, namely, the confirmation of whether or not personal data is being processed, access to the data itself, and information about the processing itself. The data subject may also obtain a copy of the personal data processed, while this possibility is not an additional right of the data subject, but rather the modality of providing access to the data. Therefore, the right of access can be understood both as the possibility for the data subject to ask the controller...”

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
47/60

treatment if personal data concerning him or her is processed, such as the possibility to access and verify this data. The data controller shall provide the data subject, based on their request, with the information included within the scope of Article 15, paragraphs 1 and 2, of the GDPR.”

“19. Access to personal data is the second component of the right of access under Article 15, paragraph 1, and constitutes the core of this right. It refers to the notion of personal data as defined in Article 4, paragraph 1, of the GDPR. Apart from basic personal data, such as name and address, an unlimited variety of data may be included in this definition, as long as it falls within the material scope of the GDPR, especially regarding how it is processed (Article 2 of the GDPR). Access to personal data means access to the actual personal data, not just a general overview of the data or a mere reference to the categories of personal data processed by the data controller. If no limits or restrictions apply, data subjects have the right to access all data processed concerning them, or parts of the data, depending on the scope of the request (see sec. 2.3.1). The obligation to provide access to the data does not depend on the type or source of such data. It applies in full even in cases where the requesting person initially provided the data to the data controller, as its purpose is to inform the data subject about the actual processing of such data by the data controller. The scope of personal data under Article 15 is explained in detail in sec. 4.1 and 4.2.”

34. When data subjects submit a request for access to their data, in principle, the information referred to in Article 15 of the GDPR must always be provided in its entirety. Consequently, when the data controller processes data relating to the data subject, the data controller shall provide all the

information referred to in Article 15, paragraph 1, and, where applicable, the information referred to in Article 15, paragraph 2. The data controller must take appropriate measures to ensure that the information is complete, accurate, and up to date, as close as possible to the state of data processing at the time of receiving the request. When two or more data controllers jointly process data, the arrangement of the joint controllers regarding their respective responsibilities in relation to the exercise of the rights of the data subject, especially regarding responses to access requests, does not affect the rights of the data subjects against the data controller to whom they direct their request.”

As can be seen, rather than a violation of the principle of data processing related to data transparency, which could imply relating it to Article 12 of the GDPR, due to the principle of specialization of typification to conduct, it is more appropriate to include it within the scope of the infringement of Article 15 of the GDPR, of the rights of the data subject that all processing of such data must respect, given its specificity which includes, within the timeframe set by the GDPR, responding to the data subject regarding whether their personal data is being processed, providing them with the actual personal data processed as well as information about the processing and about their rights, without detriment to the complements that outline Article 12 of the GDPR for all communication (clear language, timeframe to cite just one). Therefore, the legal qualification of the facts in this resolution proposal is changed in the terms specified. In this regard, the Constitutional Court has indicated that “the essential content of the constitutional right to be informed of the accusation refers to the punishable facts attributed to the accused” (STC 95/1995).

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
48/60

On the contrary, and unlike what happens with the facts, the Constitutional Court (TC), in Judgment 145/1993, warns that the communication to the alleged infringer of the legal qualification and the eventual sanction to be imposed does not constitute the essential content of the right to be informed of the accusation. So important is the notification of the facts constituting the administrative infringement that the TC has declared that the requirements of Article 24.2 of the Spanish Constitution (CE) are fundamentally satisfied with the mere communication of the alleged facts in order to be able to defend oneself against them (STC 2/1987 and 190/1987). In this regard, the Supreme Court, in its Judgment of March 3, 2004, states that “the primary purpose of the initiation agreement is to inform about the alleged facts and not about the legal qualification, which will be addressed by the resolution proposal.” In this case, the respondent only proves to have sent the applicant a burofax on December 9, 2022, outside the established deadline for response in Article 12.3 of the GDPR to an address that does not correspond to the address that the complainant provided in their application, rendering the sending ineffective. The respondent claims that only the number was provided at the address, and that was the reason for sending it to another address, the origin or purpose of which is unknown. However, the alternative means of email, which was indicated in the request, was not used, and ultimately, it does not prove to have fulfilled the right. Previously, on September 15, 2022, it sent the complainant a document without indicating any inconvenience that it now claims existed regarding the exercised right.

Furthermore, in the content of the response, which the complainant did not receive at any time, it is noted:

- A generic mention of the data available (name and surname, ID number, affiliation number, bank account number, etc.) is not sufficient; they must be specifically identified, with real data, not references to categories of data.
- It omits the reference to point 1.f) of Article 15: “the right to lodge a complaint with a supervisory authority;”
- It makes no reference to the data processed based on facial recognition as a category of data, and it omits its intended purpose, the fulfillment of a legal obligation, according to the respondent.
- It makes no reference to derived data resulting from facial recognition, such as the attendance list during the workday that reflects the marking of days through facial recognition when entering or

leaving the workplace.

Regarding the explanations of the respondent that they attempted to contact the complainant in order to deliver the response to their request, as has been demonstrated throughout the procedure, it is not proven that this was the purpose or object of the contents of the WhatsApp messages that refer to wanting to see them and deliver a document, to which the complainant indicates that it should be sent by mail first for them to read it and also that the response to their request does not require any signature.

The response to the exercise of the right of access must be proactive, adequately evaluating the request and responding without undue delay. At the same time, the data controller, the respondent, must make all reasonable efforts to...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

49/60

to ensure that the exercise of the right is facilitated. To this end, it is noted that the claimant also provided their own email address, to which the respondent did not send a copy of their response, nor did they, as reiterated, request the claimant to rectify the address, as they stated they considered it erroneous, due to the absence of the floor and door number in the postal address.

Therefore, the allegations that seek to exempt from the non-compliance of this obligation contained in Article 15 of the GDPR cannot be accepted.

VIII Qualification and Typification of the Violations

Regarding the infringement of Article 35 of the GDPR, Article 83.4 of the GDPR states: "Infringements of the following provisions shall be subject to administrative fines of up to 10,000,000 EUR or, in the case of an undertaking, an amount equivalent to up to 2% of the total annual global turnover of the preceding financial year, opting for the higher amount:

"a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43;"

The LOPDGDD establishes in its Article 73.t):

"Based on what is established in Article 83.4 of Regulation (EU) 2016/679, the following are considered serious and shall prescribe after two years: infringements that constitute a substantial violation of the articles mentioned therein and, in particular, the following:

t) The processing of personal data without having carried out the impact assessment of the processing operations on the protection of personal data where it is required."

Regarding the allegation made after the proposal by the respondent that the typification has been varied, as it appears in the same, as "not adapting their behavior consisting of carrying out a DPIA," extracted from the explanatory literal contained in the response to their allegation in the section on the infringement of Article 35: "Therefore, it is also indisputable that processing has been occurring after the entry into force of the GDPR to which the respondent has not adapted their behavior consisting of carrying out a DPIA, as determined by Recital 171 of the GDPR and is derived from the principles and guarantees applicable in the aforementioned GDPR.", it should be responded that the cited typification has not been varied, as stated in the legal basis VIII, dedicated to the issue.

Regarding the alleged infringement attributed to the respondent of Article 15 of the GDPR, it would fall under the GDPR, Article 83.5 b) "Infringements of the following provisions shall be subject to administrative fines of up to 20,000,000 EUR or, in the case of an undertaking, an amount equivalent to up to 4% of the total annual global turnover of the preceding financial year, opting for the higher amount": "the rights of the data subjects under Articles 12 to 22."

The consideration of the right of access has not undergone excessive modifications in its basic configuration in the GDPR and in the LOPDGDD. According to, among others, the Judgment of the National Court, Administrative Litigation Chamber, Section 1, appeal.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

165/2005, of 14/12/2006, it is considered that the lack of response to the right of access constitutes an impediment or obstruction in the exercise of the right, becoming an ineffective right. This interpretation is reiterated later, among others in the SAN administrative litigation chamber, section 1, appeal 556/2008 of 18/06/2009.

For the purposes of prescription, the LOPDGDD frames it in its article 72.1.k), which determines:

“1. Based on what is established in article 83.5 of Regulation (EU) 2016/679, the following are considered very serious and will prescribe after three years: infringements that constitute a substantial violation of the articles mentioned therein and, in particular, the following:

“k) The impediment or obstruction or repeated failure to attend to the exercise of the rights established in articles 15 to 22 of Regulation (EU) 2016/679.”

IX Determination of sanctions

Article 58.2 of the GDPR provides as follows: “Each supervisory authority shall have all of the following corrective powers indicated below:

i) impose an administrative fine in accordance with article 83, in addition to or instead of the measures mentioned in this section, depending on the circumstances of each particular case;”

The determination of the sanctions to be imposed in this case requires observing the provisions of articles 83.1 and 2 of the GDPR, which respectively provide as follows:

“1. Each supervisory authority shall ensure that the imposition of administrative fines under this article for the infringements of this Regulation indicated in paragraphs 4, 9, and 6 are, in each individual case, effective, proportionate, and dissuasive.”

“2. Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure for the measures contemplated in article 58, paragraph 2, letters a) to h) and j). In deciding on the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:

- a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of data subjects affected and the level of damage suffered;
- b) the intentionality or negligence in the infringement;
- c) any measures taken by the controller or processor to mitigate the damage suffered by the data subjects;
- d) the degree of responsibility of the controller or processor, taking into account the technical or organizational measures they have implemented pursuant to articles 25 and 32;
- e) any previous infringement committed by the controller or processor;
- f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement;
- g) the categories of personal data affected by the infringement;
- h) the manner in which the supervisory authority became aware of the infringement, in particular whether the controller or processor notified the infringement and, if so, to what extent;
- i) when the measures indicated in article 58, paragraph 2, have been previously ordered against the controller or processor in relation to the same matter, compliance with those measures;
- j) adherence to codes of conduct under article 40 or to certification mechanisms approved under article 42, and
- k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as financial benefits obtained or losses avoided, directly or indirectly, through the infringement.”

Within this section, the LOPDGDD contemplates in its article 76, titled “Sanctions and corrective measures”:

“1. The sanctions provided for in paragraphs 4, 5, and 6 of article 83 of Regulation (EU) 2016/679 shall be applied taking into account the criteria for graduation established in paragraph 2 of the aforementioned article.

2. In accordance with the provisions of article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

- a) The continued nature of the infringement.

- b) The connection of the infringer's activity with the processing of personal data.
 - c) The benefits obtained as a result of the commission of the infringement.
 - d) The possibility that the conduct of the affected party may have induced the commission of the infringement.
 - e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.
 - f) The impact on the rights of minors.
 - g) Having, when not mandatory, a data protection officer.
 - h) The voluntary submission by the controller or processor to alternative dispute resolution mechanisms, in cases where there are disputes between them and any data subject.
3. It will be possible, complementarily or alternatively, to adopt, when appropriate, the remaining corrective measures referred to in article 83.2 of Regulation (EU) 2016/679."

For the assessment of the sanction that would be implemented in this initiation agreement, by

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

52/60

In relation to the alleged infringement of Article 35 of the GDPR, the following factors are considered:

a) "The nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation," which was the recording of daily working hours and affected the entire workforce, 99 employees, who, having carried it out without a prior DPIA, implies a nature of the processing that creates an imbalance between the affected individuals and the data controller in the labor relationship of controlling the hours worked established by legal norm, and that could be carried out using other and various means less invasive to the employee's privacy that were not taken into consideration. Furthermore, there came a point when the respondent, despite determining that it was not appropriate, maintained it for several months, which prolonged the effects and aggravated the infringement by extending the period of repeated processing that occurs along with the retention of data on the device, in the database, and in the records. All these factors would operate as aggravating circumstances. (83.2.a GDPR).

The respondent claims that the principle of proportionality of sanctions has not been respected, as it believes that the change in the daily labor control processing system should be considered a mitigating factor. As indicated by the Supreme Court rulings, Chamber 3, of 3/12/2008 (Rec. 6602/2004) and 12/04/2012 (Rec. 5149/2009), it is the fundamental principle that underlies and governs the process of grading sanctions and implies, in legal terms, "its adequacy to the seriousness of the act constituting the infringement," as provided in Article 29.3 of Law 40/2015, on the Legal Regime of the Public Sector, given that every sanction must be determined in accordance with the severity of the infringement committed and according to a criterion of proportionality in relation to the circumstances of the act. In the GDPR, this is contained in Article 83.1, which states that each supervisory authority shall ensure that the imposition of administrative fines for infringements of the same is in each case "individual, effective, proportionate, and dissuasive."

It must be noted that the change in the timekeeping system has meant that, even acknowledging in October 2022 that the processing should cease immediately, the system was maintained, which implies that the data processing continued without having conducted the DPIA, which could condition multiple aspects regarding what its content would determine, especially regarding the necessity and proportionality of the processing and the risks to the fundamental rights and freedoms of the employees.

Regarding the respondent's claim that its actions leading to the initiation of the procedure should be considered a mitigating factor, as the system had already been replaced by the card system, it should be noted that it cannot be expected that the change occurred immediately. The respondent itself stated that it has been using the processing activity for labor control since 2016, through a system that allows for the purpose for which it processes data. After the entry into force of the GDPR, without addressing this very important obligation, it continued to serve the established purposes for compliance with the

time control established in the aforementioned labor regulations. Since the entry into force of the GDPR, biometric data has been classified as special data, and the processing carried out by the respondent as the data controller involves a high level of risk to the rights and freedoms of the affected individuals in various aspects related to its content.

Moreover, it must be taken into account that the collection and processing of data occurs between the company and employees, which implies a context of power imbalance between the parties, associated with the inadequate information regarding the processing of their data, as it was indicated that they had to give express consent for the processing of their data, including facial recognition data, when no other option was provided. Additionally, in the other

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

53/60

Infringement, the respondent was aware of the facts with the transfer of the complaint, and there is no record of their being brought up to date regarding the claimant's rights.

Finally, although it is also noted during the inspection visit that the system had been replaced, it is equally true that the expert body in data protection, the Data Protection Delegates Committee of GRUPO SAICA, the acquirer of the respondent, determined on 19/10/2022 the unsuitability of biometric data for the purpose of daily labor control, and immediately advised the replacement of the timekeeping system. It should also be taken into account that the respondent was aware of the complaint, its complete terms during the transfer procedure, as recorded in the receipt dated 21/11/2022. For this reason, and while the new system is being implemented, almost seven months later, data continues to be processed using such means for the 99 employees. The change of the system is not that it is not taken into account or will not be considered as a mitigating factor of the infringement, but rather what constitutes an aggravating factor is the maintenance of the previous system, prolonging its effects in repeated treatments over time through periods, which do not contain a DPIA (as determined by the type "The processing of personal data without having carried out the impact assessment of the processing operations on the protection of personal data"). On the other hand, the replacement of the system to mitigate the circumstance of the infringement is nothing more than fulfilling the obligation of labor time control in compliance with data protection regulations, which is merely a general obligation whose fulfillment cannot be rewarded when there has been an additional processing since it was decided that it should be abandoned, adding to the already long period in which the aforementioned DPIA should have been carried out.

It is also not explained how the aforementioned replacement relates to Article 83.2.f) of the GDPR, since the procedure had not yet been initiated and the response to the request in previous actions does not in itself imply cooperation, which could also have occurred during the transfer of the complaint in which the complaint was made evident with the facts in their terms. Such cooperation with the supervisory authority is neither more nor less than an expression of the general obligation imposed by the GDPR mentioned in Article 58.1 of the GDPR.

Finally, the mitigation of the infringement cannot be considered a mitigating factor if the system could have been discontinued close to October 2022, and yet it was extended until 28/05/2023, maintaining the lack of guarantees of the processing when it should have been mitigated closer to the first date. Despite the development of the planning of the new system, for 99 employees a transitional modality could have been used that took into account the rights of the employees, and this possibility was not chosen.

Regarding the actions carried out by SAICA as the acquirer of the respondent, it should be indicated that its management is not based on the merger or absorption of the entity that led to the transfer of responsibility to SAICA. Therefore, the fact that the system was already implemented on 7/07/2022 when it acquired CB is not sufficient to mitigate the responsibility of the respondent, given that, as the new administrator of the respondent, the decisions made that affect the respondent are enforceable against the respondent regardless of the accuracy or promptness and effectiveness of the response from the new administrator.

b)

There is a serious lack of diligence, given that it voluntarily prepared the implementation of the system and did not foresee its impact, so this factor would operate.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

54/60

as an aggravating factor. (art 83.2.b GDPR).

Regarding the defendant's claim of disagreement with this assessment of lack of diligence, considering it included in the classification of the infringement, it should be clarified that the type describes the processing without having carried out a prior DPIA. In this case, it should be noted that although there is no evidence that the entity acted with intent, the actions and the reason for not acting in accordance with the regulations reveal a serious lack of diligence in its conduct that must aggravate the infringement due to its unlawfulness. This occurs when considering the total absence of compliance with a duty that has been required since the entry into force of the GDPR, under which it acted as if there were no regulations or such duty. It bases its non-implementation of such a guarantee instrument for processing that the DPIA represents, on the assertion that the GDPR was not applicable to it due to the date it implemented and began operating the system, 2016. This statement is made without documentary or specialized expert basis on the subject that would have reasonably drawn such a conclusion, being required by the principle of proactive responsibility to comply and demonstrate compliance. In this sense, the mere fact that the conditions giving rise to the obligation to carry out a DPIA are considered by the defendant not to have been met does not diminish the general obligation of the data controllers to justify and document the reasons why a DPIA is not carried out.

However, there is no record that any document was prepared in which the necessity or not of a DPIA was evaluated, considering that the management of daily time control of personnel with the biometric system has been carried out continuously since 2016. It is an entity that, according to the data collected in its sector of activity, is a SME, with an average number of employees, 99, and should have been aware of the change in model operated for data protection purposes, as the processing of human resources data is another area that affects it. If the logic defended in the statement for its non-implementation of such a system were followed, transferable to other aspects of such obligations imposed by the GDPR (RAT, accreditation of documentary compliance with measures, data protection by design, risk analysis), none of the obligations or measures would apply to such processing, or to others that have been developed for some time, which is inadmissible from the perspective of the model that the GDPR implements, which aims to guarantee a high level of protection of such data. Thus, the established serious lack of diligence must be confirmed.

Regarding the proportionality of the sanction, according to these circumstances, it is understood as the adequacy, according to criteria of justice and equity, between the facts subject to the infringing type and the determination of the applicable sanction, taking into account the intensity of the intervening fault, that is, the degree of intent, carelessness, or negligence revealed by the conduct. And certainly, a motivation regarding the judgment of the intensity of the intervening fault is required. This would link to what is prescribed in article 83.2 b) of the GDPR.

As a consequence of the elements available, the sanction is quantified at 200,000 euros.

Regarding the infringement of article 15 of the GDPR, it must be evaluated:

- When the applicant asserts their right, the defendant entity had already been acquired by SAICA, which sends the claimant a first letter, indicating that a response will be provided,

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

55/60

but it has not credibly implemented such a response. In the CPD meeting of 23/01/2023, the issue of the procedure to address the rights of access to personal data was raised, which gives rise to the

aggravating circumstance determined by article 83.2 d) of the GDPR: due to the poor implementation of the “degree of responsibility of the data controller or the processor, taking into account the technical or organizational measures they have applied pursuant to articles 25 and 32.”

- It is also considered that there is a lack of diligence that the respondent attempts to counter in allegations through telephone contacts or via WhatsApp in order to summon him to supposedly address the exercise of the right, delivering the documentation to him, without the purpose being evidenced. The respondent is not required to take disproportionate action to fulfill the duty to attend to the right, but rather the minimum. The fact that the complainant does not go to the company at the request of a matter that is not evidenced as related to the response, and that the document was sent to another address on 9/12/2022, not the one provided by the complainant, without evidence of its receipt, shows a clear lack of diligence in the manner of fulfilling the duty to attend to that right, which could have been done differently and been effective. Therefore, if it is determined that there was a lack of diligence, it would fall under the aggravating circumstance in article 83.2.b) of the GDPR.

Regarding the allegation for this infringement that in PS/00369/2022 the principle of proportionality is violated by imposing the same fine when it had four aggravating factors, it should be noted that the nature of the treatments is different; this procedure concerns the exercise of the right of access to data related to employment, while that one was for infringement of article 17 of the GDPR, and consequently, by not granting the right, those data continued to be processed, as a debtor and receiving messages about the payment of his alleged debt, with different circumstances that do not allow for accommodation in the comparison.

Regarding the allegation that in this aggravating factor, the same fact is used to classify the infringement and apply the aggravating factor, and at the same time it is classified as very serious, not as serious or minor, it should be indicated that the types proposed for its application by the respondent, contained in articles 73.c) of the LOPDGDD, the serious, and 74.c) the minor, do not fit the conduct exhibited by the respondent and for which it has been classified, as it is evident from the reading of the first, which refers to cases in which “the identification of the affected party is not required when they have provided additional information that allows for their identification for the exercise of those rights,” a situation that does not address the present case. Likewise, it is not considered that the conduct can be classified as minor, because it has already been detailed why article 72.1.k) of the LOPDGDD is applicable.

As a consequence of the elements available, the sanction is quantified at 20,000 euros.

Regarding the allegations of the respondent about the lack of proportionality in the sanctions provided in the initiation agreement, the GDPR expresses this principle in article 83.2.1 (“Each supervisory authority shall ensure that the imposition of administrative fines under this article for the infringements of this Regulation indicated in paragraphs 4, 9, and 6 are effective, proportionate, and dissuasive in each individual case”), adding in paragraph 2 the criteria to be taken into account; for its part, article 76.2 b) specifies the mitigating or aggravating factors to be considered, in accordance with article 83.2 k) GDPR.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

56/60

In this regard, there is no inconsistency with the nature of the violations committed and the circumstances of the known facts, the degree of unlawfulness, and the attitude of the respondent upon being made aware of the claim since the transfer occurred.

Furthermore, the proportionality of the sanction is understood as the adequacy, according to criteria of justice and equity, between the facts subject to the infringing type and the determination of the applicable sanction, taking into account the intensity of the culpability involved, that is, the degree of intent, carelessness, or negligence that the conduct reveals. And of course, a justification is required regarding the assessment of the intensity of the culpability involved, which has been detailed here.

Likewise, considering that the amounts could rise in accordance with Article 83.4.a) and 83.5.a) of the GDPR, which provides for administrative fines of up to €10,000,000 and €20,000,000 for violations of

Articles 35 and 12 of the GDPR, or, in the case of a company, an amount equivalent to 2% or 4% respectively of the total annual global turnover of the previous financial year, opting for the higher amount, and noting a net turnover of (...) € in 2021, the last financial year presented.

Regarding the allegations of different treatment in the amounts of the violations, which has been made, providing data from three files, it would not be possible to compare the cases, given that the nature, scope, context, and purposes of the processing are different in each procedure.

However, it should be noted, concerning the allegation of the unequal sanction amount for the violation of the same article, comparing it with the case (...), file PS/00XXX/20XX and the turnover indicated, as well as the sanction for the violation of Article 35 that was imposed therein, it should be indicated that there was indeed a DPIA as can be deduced from the reading in which its terms are even analyzed.

SECOND FACT, points 6 and 7 among others.

In the present case, despite the fact that since 2018, with the entry into force of the GDPR, a data protection regime has been established that imposes new obligations on controllers, focused on ensuring compliance with the imposed obligations, "compliance" with the development of the new principle of proactive responsibility and the management and analysis of risks to the rights and freedoms of individuals that entails data processing, the analysis of risks to fundamental rights and freedoms. The system of proactive responsibility measures includes general obligations such as data protection by design and by default, security measures, and Data Protection Impact Assessment, and categorizes biometric data as a special category, where the risks to fundamental rights and freedoms for data protection and the processing thereof through compliance with general obligations is imperative.

Regarding the allegation that the respondent was acquired by SAICA PACK on 07/07/2022 once the system was installed, and considers that it took actions to avoid the use of the installed system, believing it should be mitigated based on Article 83.2.b).

In this sense, the new acquirer, without the original entity having disappeared, does not deduce that it has complied diligently when in the assessment of each violation it has been reasoned that this was not the case. Furthermore, in none of the actions regarding the cessation of its effects did the acquirer of CB have an effective and decisive action, as the effects of

57/60

the violations went beyond what is reasonable, regardless of the change in the timekeeping system and the time it takes to implement it.

Finally, regarding the non-application of letters b), c), e), and f) of Article 76 of the LOPDGDD, it should be indicated:

- In letter b), the fact that its main activity is not directly linked to the processing of data, such as, for example, business entities, financial institutions, or telecommunications operators, should not serve as a spur or benefit for a potential reduction in the sanction to which it is not deserving, understanding that not participating in the usual and daily traffic of personal data will not proportionally affect the severity of the infringing act. In fact, it is difficult to specify an activity or sector that does not involve the processing of data to a greater or lesser extent and with different scopes. The respondent is a business organization that manages data classified as special category, with the purpose of daily labor control, which implies that, as stated, the duration and frequency are high. From this, the respondent must assume the risk that such data may be processed in a manner contrary to the law. Considering the link between the infringer's activity and the eventual or supposed minimal processing of data as a mitigating factor can only nullify the deterrent effect of the fine, reducing by default the circumstances that may concur, which would be tantamount to considering that the non-habitual processing of data or the lack of connection of the infringer's activity with the processing of data could not produce negative effects, but rather positive ones, pre-configuring the mitigating circumstance without considering the elements that concur on a case-by-case basis, as in this case. With its deterrent effect, administrative fines contribute to reinforcing the protection of individuals regarding the processing of personal data and constitute, therefore, a key element to ensure respect for the rights of such individuals, in accordance with the purpose of the aforementioned Regulation to ensure a high level of protection for those individuals concerning the processing of personal data. In conclusion, it is not considered that this mitigating factor applies to the conduct of the respondent.

- Regarding letter c), the violations committed do not require that a benefit be produced in favor of the infringer. Regarding the lack of benefits obtained from the processing of the data subject to the claim, as a mitigating factor, this criterion of graduation is established in the LOPDGDD, in accordance with the provisions of Article 83.2.k) of the GDPR, according to which administrative fines shall be imposed taking into account any "aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement," understanding that avoiding a loss has the same nature for these purposes as obtaining benefits. If we add to this that the sanctions must be "in each individual case" effective, proportionate, and deterrent, in accordance with the provisions of Article 83.1 of the GDPR, admitting the absence of benefits as a mitigating factor is not only contrary to the factual premises contemplated in Article 76.2.c), but also contrary to what is established in Article 83.2.k) of the GDPR and to the stated principles. Thus, valuing the absence of benefits as a mitigating factor would nullify the deterrent effect of the fine, to the extent that it diminishes the effect of the circumstances that effectively impact its quantification, providing the responsible party with a benefit to which it is not deserving. It would be an artificial reduction of the sanction that could lead to the understanding that infringing the norm without obtaining benefits, financial or otherwise, "will not produce a negative effect proportional to the severity of the infringing act." It should be added that "In any case, the administrative fines established in the C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

58/60

GDPR, in accordance with the provisions of its Article 83.2, are imposed based on the circumstances of each individual case," and, in this instance, the absence of benefits is not deemed an appropriate and determining factor for assessing the seriousness of the infringing conduct. Only if this absence of benefits is relevant for determining the degree of unlawfulness and culpability present in the specific infringing act may it be considered as a mitigating factor, in application of Article 83.2.k) of the GDPR, which refers to "any other aggravating or mitigating factor applicable to the circumstances of the case." This paragraph leaves the door open for those cases where the absence of benefits may be considered a mitigating circumstance, but not according to the literal and teleological interpretation of the legislator in accordance with the provision of Article 83.2.k) of the GDPR.

- Regarding letter e), although an absorption process was not carried out, 98.52% of the shares of CARTONAJES BAÑERES were acquired. The acquisition or control of the claimed entity, which had the previously implemented system, must have been aware of the existence of such a system when it was acquired, and although it took control of that entity, it also began the direction and management of it, without such direction, aside from not fitting into that absorption, being decisive for the correction or mitigation of the effects produced.

- Regarding letter f), since it does not involve data of minors, it must be considered that the processing of such data may constitute, in some cases, an aggravating factor, but the fact that such data is not processed in itself does not constitute a mitigating factor, nor does the data controller justify in any way why this circumstance should be taken into account in this regard.

As for the last allegation indicating that after exposing the circumstances regarding the lack of proportionality, the nullity should be declared according to Article 47.1.e) of the LPACAP or, subsidiarily, annulable according to Article 48 of the same Law, such reasons, due to the failure to respect the principle of proportionality of the sanctioning amounts in their case, are not among the reasons that may lead to nullity or annulability. Furthermore, it does not reason what motive would contribute, in its opinion, to each of the requests, so the allegation cannot be accepted.

X Adoption of measures

Article 58.2 of the GDPR provides as follows: "Each supervisory authority shall have all of the following corrective powers indicated below:

"c) order the controller or processor to comply with the requests for the exercise of the rights of the data subject under this Regulation;

"

[...]

i) impose an administrative fine in accordance with Article 83, in addition to or instead of the measures mentioned in this section, depending on the circumstances of each particular case;”

The imposition of any of these measures is compatible with the sanction consisting of an administrative fine, as provided in Article 83.2 of the GDPR.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

59/60

Considering that the exercise of the right of access by the claimant has not been addressed, in accordance with the guidelines contained in the analysis of the respective infringement, as a measure to be adopted, the request for the exercise of the right by the interested party must be fully attended to, for which they must exhaust the communication channels previously offered in the request, complying with the sending and proving the receipt or availability of the attention to the aforementioned right.

In view of the above, the following is issued:

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of the sanctions whose existence has been established,

the Director of the Spanish Agency for Data Protection,

RESOLVES:

FIRST: TO IMPOSE on CARTONAJES BAÑERES, S.A. with NIF A03009263 two administrative fines for the infringement of the following articles of the GDPR:

- Article 35, in accordance with Article 83.4 a) of the GDPR, and for the purposes of the prescription of the infringement, classified as serious under Article 73.t) of the LOPDGDD, in the amount of 200,000 euros

- Article 15, in accordance with Article 83.5 b) of the GDPR, and for the purposes of the prescription of the infringement, classified as very serious under Article 72.1.k) of the LOPDGDD, in the amount of 20,000 euros.

SECOND: TO ORDER CARTONAJES BAÑERES, S.A. with NIF A03009263 that pursuant to Article 58.2.c) of the GDPR, within 30 days from the date the resolution that concludes this procedure becomes enforceable, to prove that it has complied with the exercise of the right of access of the claimant.

THIRD: TO NOTIFY this resolution to CARTONAJES BAÑERES, S.A.

FOURTH: This resolution will be enforceable once the period for filing the optional appeal for reconsideration (one month from the day following the notification of this resolution) has elapsed without the interested party having exercised this right. The sanctioned party is warned that they must pay the imposed sanction once this resolution becomes enforceable, in accordance with the provisions of Article 98.1.b) of Law 39/2015, of 1/10, on the Common Administrative Procedure of Public Administrations (hereinafter LPACAP), within the voluntary payment period established in Article 68 of the General Collection Regulation, approved by Royal Decree 939/2005, of July 29, in relation to Article 62 of Law 58/2003, of 17/12, by making the payment, indicating the NIF of the sanctioned party and the procedure number that appears in the heading of this document, into the restricted account no. IBAN: ES00-0000-0000-0000-0000-0000 (BIC/SWIFT Code: CAIXESBBXXX), opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A. Otherwise, collection will proceed in the executive period.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

60/60

Upon receiving the notification and once it is enforceable, if the date of enforceability falls between the 1st and the 15th of each month, inclusive, the deadline for voluntary payment will be until the 20th of

the following month or the next business day, and if it falls between the 16th and the last day of each month, inclusive, the payment deadline will be until the 5th of the second following month or the next business day.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file a reconsideration appeal before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and section 5 of the fourth additional provision of Law 29/1998, of 13/07, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided in Article 16.4 of the aforementioned LPACAP. They must also provide the Agency with documentation proving the effective filing of the contentious-administrative appeal. If the Agency does not become aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, the provisional suspension will be considered terminated.

938-16012024

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es